

國立臺北商業大學

資訊管理系

115' 資訊系統專案設計

系統手冊



組 別：第 115206 組

題 目：RiskGenie 評評理

指導老師：徐國鈞老師

組 長：11436017 顏珮倪

組 員：11436008 林紀煊 11436010 李昕縈

11436021 黃翊甄 11436029 林敬芬

中 華 民 國 1 1 5 年 0 6 月 0 1 日

目錄

第 1 章 前言	1
1-1 背景介紹	1
1-2 動機	1
1-3 系統目的與目標	2
1-4 預期成果	3
第 2 章 營運計畫	5
2-1 可行性分析	5
2-2 商業模式	7
2-3 市場分析 — STP	9
2-4 競爭力分析 SWOT-TOWS	11
第 3 章 系統架構	13
3-1 系統架構	13
3-2 系統軟、硬體需求與技術平台	14
3-3 使用標準與工具	15
第 4 章 專案時程與組織分工	19
4-1 專案時程：甘特圖	19
4-2 專案組織與分工	19
4-3 上傳 GitHub 紀錄	22
第 5 章 需求模型	23
5-1 使用者需求	23

5-2 使用個案圖	25
5-4 分析類別圖	39
第 6 章 設計模型	40
6-1 循序圖	40
6-2 設計類別圖	48
第 7 章 實作模型	49
7-1 佈署圖	49
7-2 套件圖	49
7-3 元件圖	50
7-4 狀態機圖與時序圖	51
第 8 章 資料庫設計	52
8-1 資料庫關聯表（參考關係與限制 Constraints）	52
8-2 表格及其 Meta Data	53
第 14 章 參考資料	57

圖目錄

圖 3-1-1 系統架構圖	14
圖 4-1-1 專案時程：甘特圖	19
圖 4-3-1 GitHub 紀錄	22
圖 5-2-1 使用個案圖	25
圖 5-3-1 活動圖－登入作業	26
圖 5-3-2 活動圖－新增資訊資產作業	27
圖 5-3-3 活動圖－刪除資訊資產作業	28
圖 5-3-4 活動圖－修改資訊資產作業	29
圖 5-3-5 活動圖－查詢資訊資產作業	30
圖 5-3-6 活動圖－資產盤點與 AI 建議作業	31
圖 5-3-7 活動圖－風險評鑑作業	32
圖 5-3-8 活動圖－風險評鑑與 AI 建議作業	33
圖 5-3-9 活動圖－風險報表產生作業	34
圖 5-3-10 活動圖－查詢帳號作業	35
圖 5-3-11 活動圖－新增帳號作業	36
圖 5-3-12 活動圖－備份系統資料作業	37
圖 5-3-13 活動圖－備份系統資料作業	38
圖 5-4-1 分析類別圖	39
圖 6-1-1 循序圖－登入作業	40
圖 6-1-2 循序圖－新增資訊資產作業	41

圖 6-1-3 循序圖－刪除資訊資產作業	41
圖 6-1-4 循序圖－修改資訊資產作業	42
圖 6-1-5 循序圖－查詢資訊資產作業	42
圖 6-1-6 循序圖－資產盤點與 AI 建議作業	43
圖 6-1-7 循序圖－風險評鑑作業	44
圖 6-1-8 循序圖－風險評鑑 AI 建議作業	45
圖 6-1-9 循序圖－風險報表產生作業	45
圖 6-1-10 循序圖－查詢帳號作業	46
圖 6-1-11 循序圖－新增帳號作業	46
圖 6-1-12 循序圖－修改/停用帳號作業	47
圖 6-1-13 循序圖－備份系統資料作業	47
圖 6-2-1 設計類別圖	48
圖 7-1-1 佈署圖	49
圖 7-2-1 前端套件圖	49
圖 7-2-2 後端套件圖	49
圖 7-3-1 元件圖	50
圖 7-4-1 狀態機圖	51
圖 7-4-2 時序圖	51
圖 8-1-1 資料庫關聯表	52

表目錄

表 2-2-1 商業模式	7
表 2-2-2 學生專題階段－成本的量化估算	8
表 2-2-3 商業化階段－成本的量化估算	8
表 2-2-4 商業化階段－收益的量化估算	9
表 2-3-1 市場區隔	9
表 2-4-1 SWOT 分析	11
表 2-4-2 TOWS 分析	11
表 2-4-3 相關系統比較	12
表 3-2-1 系統軟體需求	15
表 3-2-2 系統硬體需求	15
表 3-3-1 系統開發環境與工具	18
表 4-2-1 專案組織與分工	19
表 4-2-2 專題成果工作內容與貢獻度表	21
表 5-1-1 功能需求清單	23
表 5-1-2 非功能需求清單	24
表 8-2-1 companies(公司表) 欄位定義	53
表 8-2-2 departments (部門表) 欄位定義	53
表 8-2-3 role(角色表) 欄位定義	53
表 8-2-4 users (使用者表) 欄位定義	53
表 8-2-5 assets (資產表) 欄位定義	53

表 8-2-6 vulnerabilities (弱點表) 欄位定義	54
表 8-2-7 risk_assessments (AI 風險分析結果表) 欄位定義	54
表 8-2-8 audit_logs (稽核紀錄表) 欄位定義	55

第 1 章 前言

1-1 背景介紹

隨著全球數位化與雲端服務的普及，資訊安全已成為組織營運不可或缺的一部分。為建立具備國際公信力的資安防護體系，許多組織選擇導入 ISO 27001 資訊安全管理系統 (ISMS)。在 ISMS 的標準維運 PDCA 流程中，「資產盤點」與「風險評鑑」是決定資安政策成敗的關鍵前期作業。

然而，現行的實務運作高度依賴人工填寫與主觀判斷。組織內的資安承辦人員通常需要面對成百上千筆的 Excel 資產表格，逐一填寫各項資產的機密性 (C)、完整性 (I)、可用性 (A) 分級。由於缺乏客觀的參照標準，不同的承辦人員常因個人經驗差異，可能無法對於相同資產給出客觀的評價。

此外，面對日新月異的資安威脅與新興漏洞，人工方式導致風險評鑑往往淪為應付稽核的靜態文書作業，難以反映現實中動態的威脅環境。

1-2 動機

本專題之研發動機，源於發現組織在執行 ISMS 風險評鑑時，企業所面臨的實務痛點：

(一) 資安承辦人員的標準不一的問題：

承辦人員在面對跨部門匯入的原始 Excel 資產盤點表時，難以在短時間內核對資產分類的正確性，無法憑一己之力了解所有硬體設備或軟體版本的已知漏洞。這導致弱點與威脅值的評估會主觀的憑感覺填寫。

（二）資安主管的決策困境：

由於傳統評鑑可能導致風險分數失真，主管無法精確掌握真正面臨的「關鍵風險項目」，造成資安預算與人力資源的錯配。

（三）隱私外洩與 AI 幻覺：

雖然引進大型語言模型能輔助分析，但資安資料極度敏感。若將包含組織名稱、內部 IP 等機敏資料直接上傳雲端 AI，將引發嚴重的資安外洩危機；且 AI 的「幻覺現象」可能產出錯誤的資安法規與對策建議，這在講求精確合規的資安稽核中是不被允許的。

因此，如何建構一套專注於資安面向、具備隱私防護機制，並能動態串接外部漏洞情資與 ISO 標準規範的智慧化顧問系統，成為本組的研究重點。

1-3 系統目的與目標

本專題旨在開發一套名為「RiskGenie 評評理」的支援 ISMS 運作之 AI 風險顧問系統。透過將「AI 智能」與「合規規則引擎」深度結合，協助組織將原先繁瑣且主觀的人工作業，轉化為數據驅動的標準合規流程。

系統具備四大具體目標：

1. 建立利害關係人導向的智慧盤點功能：支援批次匯入組織既有的 Excel 資產表，由 AI 進行欄位對齊與語意分析，客觀給予資產分類與 CIA 價值建議，並自動生成分級理由以供外部稽核員查核。

2. 實作數據驅動與彈性公式的動態風險評鑑： 定期更新 NVD/CVE 漏洞情資至本地資料庫，將外部真實的漏洞 CVSS 分數引入系統。系統透過排程機制自動更新本地漏洞快取，確保風險評鑑在無需即時連線外部服務的情況下，仍能取得準確的漏洞數據進行計算。同時，系統架構預留公式彈性，能兼容不同組織自定義的風險計算需求。
3. 建構機敏資料去識別化防護層： 在資料傳輸至雲端模型前，系統將自動進行隱私過濾，遮蔽具備辨識性的機構名稱與關鍵參數，在完全保障資安隱私的前提下發揮 AI 的分析效益。
4. 建置基於 RAG 技術的合規方式： 透過檢索增強生成技術，強制 AI 依據 ISO 27002:2022 的標準控制措施知識庫進行建議生成，根除 AI 幻覺，自動產出具備高度精確性與實作價值的資安改善 SOP 草案。

1-4 預期成果

本系統預期在實務與管理層面達成以下成果：

1. 大幅提升資安行政效率： 將原本需耗時數週的資產比對與漏洞查詢工作，縮短至數分鐘內批次完成，降低資安承辦人員的行政負擔。
2. 落實「人機協同」與差異分析透明化： 系統將清晰呈現「原始資料」與「AI 建議」的差異。系統定位為「顧問」，最終決策權仍保留給人工審核，並詳實記錄人工檢驗與修正的軌跡，確保決策的正確性與可追溯性。
3. 優化組織資安資源分配： 透過修正後的最大風險演算法，為資安主管產出準確

的風險熱力圖與高風險分佈報告，使組織能將有限的資源精準投注在最脆弱的防護破口上。

4. 提供安全、合規且具公信力的資安文件：在確保機敏資料不外洩的安全框架下，產出符合國際標準的風險處理計畫書與標準作業程序（SOP），輔助組織順利通過 ISO 27001 稽核。

第 2 章 營運計畫

2-1 可行性分析

1. 市場需求分析：

台灣已通過 ISO 27001 驗證的組織約以千為單位,加上預備導入、教育部資通安全等級要求的學校，以及金管會逐年加嚴的金融業要求，ISMS 文書負擔的問題本身存在，但中大型企業已被 E-SOFT、Secorion 等既有合規平台覆蓋。我們挑的不是與它們正面對撞，而是「買不起合規平台又必須做 ISMS」這塊：中小企業、學校、地方公部門。這正是 RiskGenie 想解的場景。

2. 技術可行性分析：

- 系統功能可透過一般 Web 架構實作：

本系統功能包含登入、資訊資產新增、刪除、修改、查詢、資產盤點檢查、風險評鑑、AI 改善建議、風險報表、帳號權限管理及資料備份等，皆可透過前端介面、後端程式、資料庫與 API 串接完成。

- 開發技術具備可取得性：

系統可採用 Python 作為後端開發語言，並搭配資料庫儲存資產資料、風險評估結果與使用者資料，技術門檻符合學生專題可實作範圍。

- AI 功能可透過外部 API 輔助完成：

AI 改善建議可串接外部 AI 模型 API 產生初步建議，再由使用者進行確認與修正，不需自行訓練大型 AI 模型。

- 系統以主要流程展示為目標：

本專題屬於學生專題階段，重點在於完成可展示的主要流程，不以完整商業化平台為目標，因此技術範圍較容易控制。

- 需注意技術風險：

系統仍需注意 AI 回答正確性、資料安全性、伺服器穩定性與後續維護成本。

3. 風險與挑戰：

- 專題階段以功能驗證為主：

學生專題階段主要目標為概念驗證與功能展示，重點在於證明系統能支援 ISMS 相關流程，包括資產盤點、風險評鑑與 AI 改善建議。

- 團隊可依功能模組分工：

團隊可依系統功能進行分工，例如資產管理模組、風險評鑑模組、AI 建議模組、報表模組與帳號權限模組，降低開發與管理負擔。

- 未來可採訂閱制模式發展：

若未來朝商業化發展，系統可採用 SaaS 訂閱制，讓使用單位依每月或每年方式付費使用。

- 功能可分階段擴充：

初期可提供資產盤點、風險評鑑與 AI 改善建議等基本功能；後續再加入多部門管理、權限控管、報表匯出與外部情資串接等進階功能。

● 營運風險可逐步控管：

由於本系統初期以專題展示為主，可先降低伺服器、客服與商業推廣成本，待系統成熟後再評估正式營運需求。

2-2 商業模式

表 2-2-1 商業模式

關鍵合作夥伴	關鍵活動	價值主張	顧客關係	目標客群
	關鍵資源		通路	
AI 模型供應商、雲端服務供應商、ISMS 顧問公司	- 平台開發和維護 - 資安知識庫更新 - 用戶支持與客戶服務 - 市場營銷和推廣	- 降低資安風險成本 - 即時、高效的追蹤風險 - 降低資安風險評鑑門檻 - 提供 AI 白話化改善建議	- 定期更新 - 用戶互動	所有導入 ISMS 的企業
成本結構 - 伺服器與資料庫成本 - 系統開發與維護成本 - AI API 使用成本 - 行銷推廣成本		收益流 - 訂閱制收入 - 顧問合作分潤 - 企業版授權		

表 2-2-2 學生專題階段－成本的量化估算

成本項目	估算依據	金額
開發人力(機會成本)	5 人 × 80 小時 × NT\$200 / 小時	NT\$80,000(一次性)
雲端資料庫	Supabase Free Tier(500 MB)	NT\$0 / 月
AI API 測試用量	Gemini API 免費額度加少量付費	NT\$300 / 月
其他工具與部署	網域、測試環境	NT\$500 / 月
小計		一次性 NT\$80,000 + NT\$800 =NT\$80,800 / 月

表 2-2-2 成本的量化估算說明：在學階段沒有實際付薪資，但為符合系統企劃成本估算邏輯，以工讀時薪 NT\$200 估機會成本。

表 2-2-3 商業化階段－成本的量化估算

成本項目	估算依據	估算金額
系統維護人力	1 名兼職工程師或維護人員	NT\$60,000 / 月
雲端伺服器與資料庫	伺服器、資料庫、備份與流量費用	NT\$5,000 / 月
AI API 使用費	依使用者查詢與改善建議產生次數估算	NT\$10,000 / 月
系統維護與資安防護	系統更新、弱點修補、權限與備份維護	NT\$10,000 / 月
行銷推廣成本	線上推廣、簡介製作與合作推廣	NT\$15,000 / 月
小計		NT\$100,000 / 月

2-2-4 商業化階段－收益的量化估算

收益項目	假設條件	估算金額
訂閱制收入	500 單位 × NT\$500／月	NT\$250,000／月
企業版或進階功能收入	進階報表、權限管理或客製化功能	NT\$20,000／月
合作夥伴收入	顧問公司推薦或合作推廣	NT\$20,000／月
小計		NT\$290,000／月

2-3 市場分析 — STP

一、市場區隔(Segmentation)

我們從組織規模、產業屬性、ISMS 導入階段三個軸切市場，如表 2-3-1 市場區隔所示。

表 2-3-1 市場區隔

軸線	區隔	特性	對 RiskGenie 的需求度
組織規模	中小企業	資安人力 0-1 人,常委外	高
	中大型企業	已有內部團隊或既有合規平台	中(切入難度高)
	顧問公司	同時服務多家客戶	中(可作為通路)
產業屬性	學校與公部門	預算受限,合規壓力來自上級機關	高
	科技與製造	資產量大、供應鏈合規要求	中
	金融與醫療	法規最嚴,但既有平台覆蓋深	低(暫不打)
ISMS 導入階段	預備導入	缺範本與流程引導	高

	導入中	正在整理資產與評鑑	高
	已導入	例行維護與報表	中

二、目標市場(Targeting)

初期鎖定：預備導入或導入中的學校單位與中小企業。理由：

1. 資安人力薄弱,工具替代人力的價值最直接;
2. 預算敏感,既有合規平台對他們太貴,我們有價格空間;
3. 資產規模可控(數百至數千筆)。

中長期擴張：資安顧問公司(作為通路放大器,而非直接客戶)、以及中大型企業的進階版需求。金融與醫療因法規門檻與信任建立成本過高，本專題期程內不主動切入。

三、產品定位(Positioning)

本系統不是完整取代資安顧問，也不是大型企業使用的完整合規管理平台，而是提供一套較低門檻、較容易操作的輔助工具。其定位重點如下：

1. 低門檻：以簡單介面協助使用者完成資料填寫與查詢。
2. 高效率：減少人工盤點與填寫風險評估表的時間。
3. 可理解：AI 將資安建議轉換為較白話的改善方向。
4. 保留人工判斷：AI 僅提供建議，最終結果仍由使用者確認。

2-4 競爭力分析 SWOT-TOWS

表 2-4-1 SWOT 分析

優勢 S	劣勢 W
1. 「AI 給建議、規則算分、RAG 給來源」三層架構,風險分數可解釋、可重算、可審計 2. 保留人工值、另存 AI 建議與 cia_delta,差異分析透明 3. CIA 權重可由使用者調整,方法論非黑箱 4. 鎖定 ISO 27002:2022,對齊現行國際標準	1. 多租戶、權限控管、情資快取等商業化要件未完成 2. 依賴 Gemini 單一 LLM 供應商 3. 知識庫須隨 ISO 標準更新人工維護
機會 O	威脅 T
1. 教育部資通安全等級要求逐年加嚴,學校單位需求升溫 2. 中小企業 ISMS 導入意願提升,但缺工具 3. 生成式 AI 應用接受度普及,組織願意嘗試 4. 顧問公司可能採用本系統提升輔導效率	1. E-SOFT、Secorion 等合規平台已具品牌與客戶基礎 2. 資安資料敏感,雲端 AI 工具信任建立慢 3. ISO 標準與法規變動,需持續維護成本 4. AI 建議錯誤可能造成使用者信任流失

表 2-4-2 TOWS 分析

	優勢 S	劣勢 W
機會 O	以三層架構的可解釋性切入學校與中小企業,主打「比 Excel 快、比顧問便宜、比合規平台輕」	學生階段不打多租戶,但用 PoC 在學校單位累積案例,後續再投入企業級功能
威脅 T	以「規則引擎算分、AI 不直接決定分數」回應對 AI 信任的疑慮;以條文引用回應 AI 幻覺風險	不過度宣稱商業成熟度,定位明確為輔助工具與 PoC,避免與企業級平台直接競爭

表 2-4-3 相關系統比較之評比依據：依各系統公開官網與導入文件(2026/04 查詢) 整理。

表 2-4-3 相關系統比較

比較項目	RiskGenie 評評理	E-SOFT	Secorion 資安合規
主要定位	AI 輔助 ISMS 風險評鑑	企業資安管理	資安合規管理
目標客群	學校、中小企業、ISMS 初期	中大型企業	中大型企業
使用門檻	低(下拉選單與匯入)	中高(需設定)	中高(需顧問導入)
AI 輔助	三層架構, 引用條文	較低或客製化	較低
風險評鑑效率	高(自動計算與建議)	中	中
報表能力	風險報表與高風險清單	完整管理報表	完整合規報表
導入成本	低	高	高
多租戶	規劃中(Phase 2 後期)	已具備	已具備

差異化重點：RiskGenie 不與企業級平台正面競爭,而是補上「人力不足做不了風險評鑑」這塊既有平台不服務的市場。

第 3 章 系統架構

3-1 系統架構

本系統旨在輔助使用者進行資訊資產盤點與風險評鑑，降低傳統人工評鑑所需的時間與專業門檻，並提升整體資安管理效率。透過使用者輸入資產資料，結合生成式人工智慧（Gemini）與檢索增強生成技術（RAG）進行分析，自動產出風險評鑑結果與建議措施，以提供使用者作為決策參考。系統架構主要分為三個部分：

1. 前端介面：使用 HTML、CSS 與 JavaScript 建構操作介面，提供使用者直覺化的操作環境。使用者可透過網頁進行資產盤點、風險評鑑與結果查詢，提升操作便利性與使用體驗。
2. 後端服務：採用 Python Flask 框架進行開發，負責系統核心邏輯、資料處理、RESTful API 服務建置，以及 Gemini 模型串接功能。系統導入 RAG 技術，透過定期蒐集與更新公開漏洞資料（CVE）至本地知識庫，作為風險分析之參考依據。當使用者執行資產盤點或風險評鑑時，系統會先檢索知識庫中與資產相關之漏洞資訊，再結合使用者輸入資料提供給 Gemini 模型進行分析與建議生成，以提升評鑑結果之準確性與即時性。
3. 資料庫與系統整合：使用 Supabase 雲端資料庫（PostgreSQL）進行資料儲存與管理，負責保存使用者資料、資訊資產清單、風險評估結果及 CVE 漏洞知識庫資料。系統透過排程機制定期同步最新 CVE 資訊，以確保風險評鑑所依據之資安資料具備時效性。

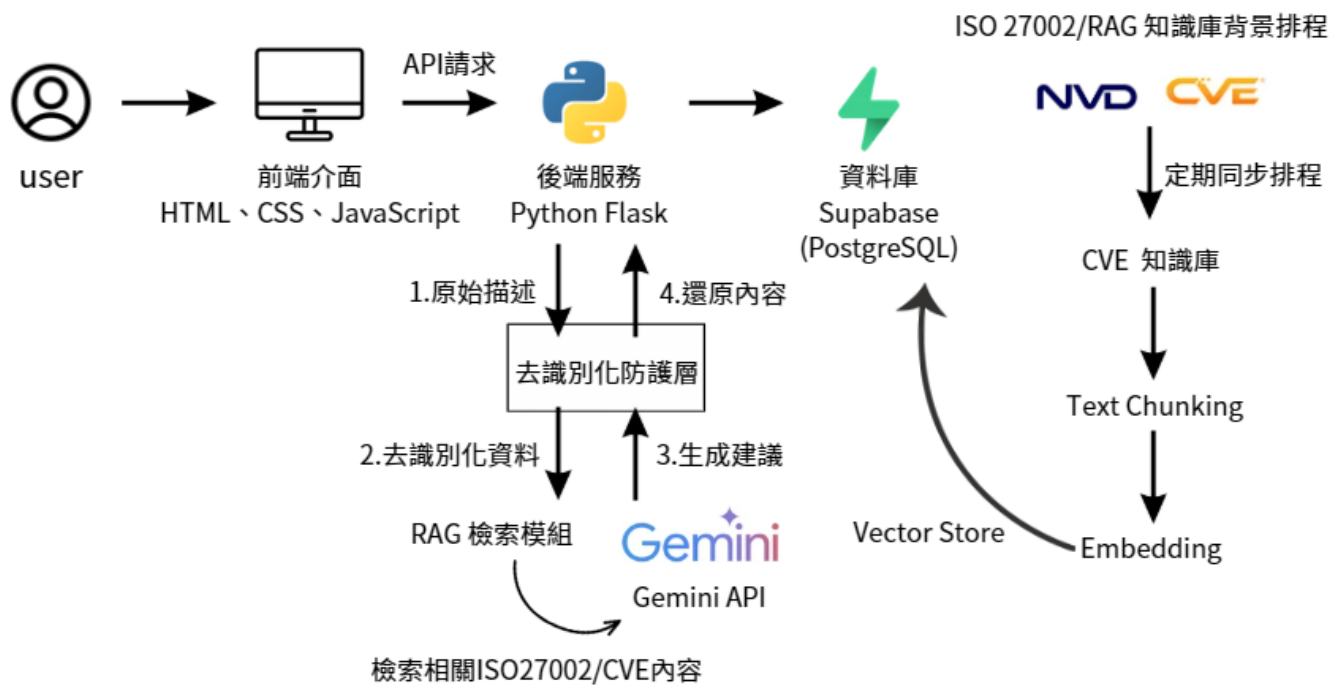


圖 3-1-1 系統架構圖

圖 3-1-1 顯示本系統之整體架構。本系統採用前後端分離架構，使用者透過前端介面發送 API 請求至後端 Flask 伺服器，由後端統一協調資產盤點與風險評鑑相關模組進行處理。在進行 Gemini API 呼叫前，系統於後端導入雙重資料保護與知識增強機制。首先透過「去識別化防護層」對資產描述及敏感資訊進行遮罩處理，以確保資料隱私與安全性。接著啟動「RAG 檢索模組」，透過 Supabase 向量資料庫進行語意相似度檢索，其資料來源包含定期更新之 CVE 弱點資訊與 ISO 27002 資安控制規範，以提供模型更完整之資安背景知識。最終，系統將去識別化後之輸入資料與檢索結果一併輸入至 Gemini API，以生成具備情境脈絡與資安依據之改善建議。

3-2 系統軟、硬體需求與技術平台

本系統採用現代化網頁技術架構，以 HTML、CSS 與 JavaScript 建構前端介面，並結合 Python Flask 後端框架與 Supabase 雲端資料庫，建置一套完整的資安風險評

估平台。考量現今使用者多透過不同裝置進行操作，本系統設計為跨平台網頁應用，支援電腦與行動裝置瀏覽器，使用者可隨時進行資產盤點與風險評鑑。此外，由於採用 Supabase 作為雲端資料庫服務，可降低傳統資料庫伺服器建置與維護成本，並提升資料同步、備份與存取之便利性。系統軟、硬體需求如下：

表 3-2-1 系統軟體需求

項目	需求規格說明
作業系統	Windows / macOS / Linux
前端技術	HTML、CSS、JavaScript
後端技術	Python Flask
資料庫	Supabase (PostgreSQL 雲端資料庫)
API 設計	RESTful API
技術與模型	RAG、Gemini
開發工具	Visual Studio Code
版本控制	GitHub
瀏覽器	Chrome、Edge、Safari

表 3-2-2 系統硬體需求

項目	需求規格說明
裝置類型	支援瀏覽器之電腦、手機或平板
作業系統	Windows 10 以上 / macOS / Android / iOS
記憶體	建議 4GB 以上
網路需求	穩定網際網路連線
儲存空間	至少 50MB (用於暫存資料)

3-3 使用標準與工具

以下列出本系統於開發「RiskGenie 評評理」時所使用之主要開發工具與技術，並說明其特點與選用理由：

- 1. 開發工具與技術說明：

- Python：具備語法簡潔、可讀性高與開發效率佳等特性，並擁有豐富的第三方套件資源，適合用於後端開發與資料處理。本系統採用 Python 作為主要後端開發語言，以提升系統開發效率與維護性。
- Flask：為 Python 的輕量級 Web 框架，具備高彈性與擴充性。本系統透過 Flask 實作後端服務，處理資產資料、風險評估邏輯與使用者管理功能。
- Supabase：為基於 PostgreSQL 之雲端資料庫平台，提供資料儲存與 API 整合功能。本系統用於儲存使用者資料、資產清單與風險評估結果，以提升資料管理效率與系統擴充性。
- HTML / CSS / JavaScript：作為前端開發之標準技術，負責使用者介面呈現與互動功能實作，並支援多裝置瀏覽，提升使用者體驗。
- Gemini 生成式人工智慧模型：用於風險分析與建議生成，以提升分析效率與決策品質，並於資料傳送前進行敏感資訊去識別化處理，以降低敏感資料外洩風險並提升資料安全性。
- RAG 檢索增強生成技術：透過檢索增強生成（RAG）技術，從本地資安知識庫中擷取與使用者資產相關之資訊，並將檢索結果作為 Gemini 模型之額外上下文資訊，以提升分析準確性。該知識庫內容包含定期更新之 CVE 漏洞資料與相關資安規範，使系統能反映最新資安威脅情境。透過結合檢索資料與生成式 AI 分析，可降低模型產生錯誤資訊之風險，並提升風險評鑑結果與改善建議之可信度與即時性。

- Visual Studio Code：為輕量且功能完整之開發工具，支援多種程式語言與除錯功能，並可透過擴充套件提升開發效率，是本系統主要開發環境。
- GitHub：用於版本控制與專案管理，支援多人協作開發、版本追蹤與程式碼備份，有助於提升團隊開發效率與程式品質。

2. 軟體工程標準：

- UML：用於系統分析與設計，包含系統架構圖、循序圖與類別圖等，以提升系統設計之完整性與可讀性。
- RESTful API 設計原則：作為前後端資料傳輸之設計依據，使系統架構清晰，並提升系統之擴展性與維護性。

表 3-3-1 系統開發環境與工具

系統開發環境	
作業系統	Windows 11
開發平台	HTML、JavaScript、Python、Flask、Supabase
程式撰寫工具	Visual Studio Code
程式開發工具	
前端技術	HTML、CSS、JavaScript
後端技術	Python、Flask、Supabase（PostgreSQL）
API 設計	RESTful API
技術與模型	RAG、Gemini
文件美工工具	
圖表設計	Visual Paradigm Online
文件	Microsoft Word
簡報	Microsoft PowerPoint、Canva
專案管理平台	
版本與專案管理	GitHub
檔案儲存	GitHub、OneDrive

第 4 章 專案時程與組織分工

4-1 專案時程：甘特圖

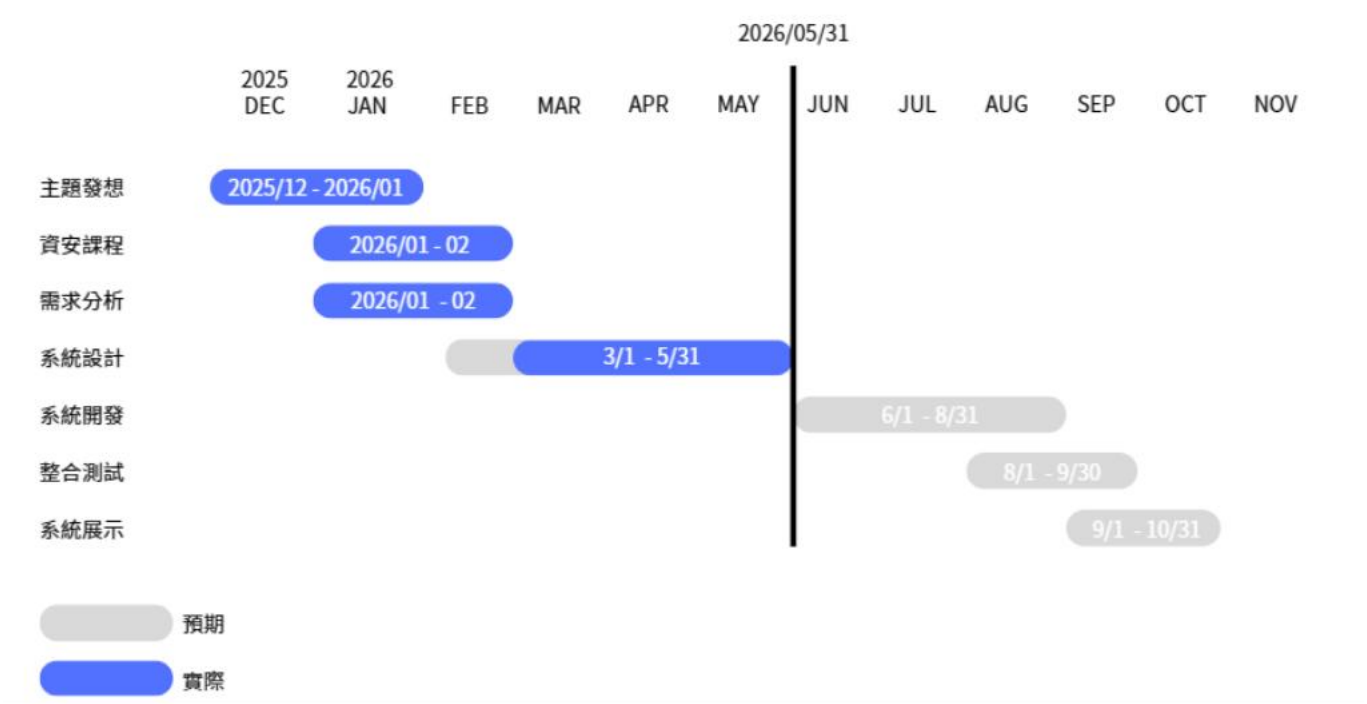


圖 4-1-1 專案時程：甘特圖

4-2 專案組織與分工

本專題由五位組員共同完成，依系統功能、文件撰寫及成果展示需求進行工作分配。符號說明：●主要負責人 ○次要負責人

表 4-2-1 專案組織與分工

項目/組員		11436008 林紀煊	11436010 李昕縈	11436017 顏珮倪	11436021 黃翊甄	11436029 林敬芬
後端 開發	資料庫建置	●			○	
	伺服器架設				●	
	登入作業			●		
	新增資訊資產作業	●				
	刪除資訊資產作業	●				
	修改資訊資產作業	●				
	查詢資訊資產作業	●				
	資產盤點與 AI 建議	●				

	風險評鑑作業					●
	風險評鑑 AI 建議		●			
	風險報表產生作業		●			
	帳號與權限管理作業			●		
	備份系統資料作業			●		
前端 開發	登入作業			●		
	新增資訊資產作業				●	
	刪除資訊資產作業				●	
	修改資訊資產作業				●	
	查詢資訊資產作業				●	
	資產盤點與 AI 建議				●	
	風險評鑑作業				●	
	風險評鑑 AI 建議				●	
	風險報表產生作業				●	
	帳號與權限管理作業			●		
	備份系統資料作業			●		
美術 設計	UI/ UX				●	
	Web/APP 介面設計				●	
	色彩設計				●	
	Logo 設計					●
	素材設計				●	
文件 撰寫	統整		●			
	第 1 章 前言					●
	第 2 章 營運計畫				●	
	第 3 章 系統規格		●			
	第 4 章 專題時程與組織分工			●		
	第 5 章 需求模型			●	○	
	第 6 章 設計模型		●			
	第 7 章 實作模型	●				○
	第 8 章 資料庫設計	●				
	第 9 章 程式					
	第 10 章 測試模型					
	第 11 章 操作手冊					
	第 12 章 使用手冊					
報告	簡報製作			●		

表 4-2-2 專題成果工作內容與貢獻度表

序號	姓名	工作內容<各限 100 字以內>	貢獻度
1	組長 11436017 顏珮倪	● 前端：登入作業、帳號與權限管理作業、備份系統資料作業 ● 後端：登入作業、帳號與權限管理作業、備份系統資料作業 ● 文件：第 4 章、5-1、5-2	<u>20%</u>
2	組員 11436008 林紀煊	● 資料庫建置 ● 後端：新增資訊資產作業、刪除資訊資產作業、修改資訊資產作業、查詢資訊資產作業、資產盤點與 AI 建議 ● 文件：7-1、7-2、第 8 章	<u>20%</u>
3	組員 11436010 李昕縈	● 後端：風險評鑑 AI 建議、風險報表產生作業 ● 文件：第 3 章、第 6 章	<u>19%</u>
4	組員 11436021 黃翊甄	● 資料庫建置 ● 前端：新增資訊資產作業、刪除資訊資產作業、修改資訊資產作業、查詢資訊資產作業、資產盤點與 AI 建議、風險評鑑作業、風險評鑑 AI 建議、風險報表產生作業 ● 文件：第 2 章、5-3、5-4	<u>22%</u>
5	組員 11436029 林敬芬	● 後端：風險評鑑作業 ● 文件：第 1 章、7-3、7-4	<u>19%</u>
			總計:100%

4-3 上傳 GitHub 紀錄



圖 4-3-1 GitHub 紀錄

第 5 章 需求模型

本章依據系統利害關係人目標與主要作業流程，整理 RiskGenie 評評理之功能需求、非功能需求與使用個案模型。本系統使用者包含一般使用者、資安管理員／高階主管及系統管理員；各項需求以資訊資產盤點、風險評鑑與 AI 改善建議為核心。

5-1 使用者需求

● 功能需求

功能需求依本系統 11 項主要作業整理，使需求清單、使用個案圖與後續設計模型具有一致的對應關係。

表 5-1-1 功能需求清單

編號	功能需求名稱	需求說明	使用者角色
FR-01	登入作業	提供帳號密碼登入功能，並依角色導向可使用之功能。	所有角色
FR-02	新增資訊資產作業	新增資產名稱、類別、負責人、用途與 CIA 等必要資料。	一般使用者
FR-03	刪除資訊資產作業	刪除不再使用或登錄錯誤之資訊資產資料。	一般使用者
FR-04	修改資訊資產作業	修改既有資產資料，使盤點內容維持正確。	一般使用者
FR-05	查詢資訊資產作業	依資產名稱、類別或負責人等條件查詢資產。	一般使用者
FR-06	資產盤點與 AI 建議作業	檢查資產資料完整性，提示缺漏資料，並提供 AI 資產分類及 CIA 價值建議供確認。	一般使用者
FR-07	風險評鑑作業	依資產價值、威脅與弱點等資料計算風險值，並顯示風險等級。	一般使用者
FR-08	風險評鑑 AI 建議作業	依風險評鑑結果產生改善建議，供使用者查看與後續處理參考。	一般使用者
FR-09	風險報表產生作業	提供整體風險報表與高風險資產資訊，協助掌握優先處理項目。	資安管理員/ 高階主管
FR-10	帳號與權限管理作業	新增、修改或停用使用者帳號，並設定角色權限。	系統管理員

編號	功能需求名稱	需求說明	使用者角色
FR-11	備份系統資料作業	執行或管理系統資料備份，以降低資料遺失風險。	系統管理員

● 非功能需求

表 5-1-2 非功能需求清單

編號	非功能需求名稱	需求說明
NFR-01	安全性與權限控管	系統應透過登入驗證與角色權限限制功能存取，避免未授權操作。
NFR-02	易用性	介面應清楚易操作，使使用者可完成資產盤點、風險評鑑與建議查看。
NFR-03	可靠性	系統應穩定儲存與處理資產及風險資料，避免資料錯誤或遺失。
NFR-04	效能	一般查詢與結果顯示應於合理時間內完成，不造成明顯等待。
NFR-05	可追溯性	系統應保留資產資料、評鑑結果與 AI 建議，以利後續查詢與追蹤。
NFR-06	可維護性	系統功能模組應具備明確分工，方便後續修改與擴充。
NFR-07	AI 建議可解釋性	AI 提供分類、CIA 價值或改善建議時，應呈現可供使用者判斷之理由。
NFR-08	人工確認原則	AI 輸出僅作為輔助建議，使用者可依實際情況確認或修正。

5-2 使用個案圖

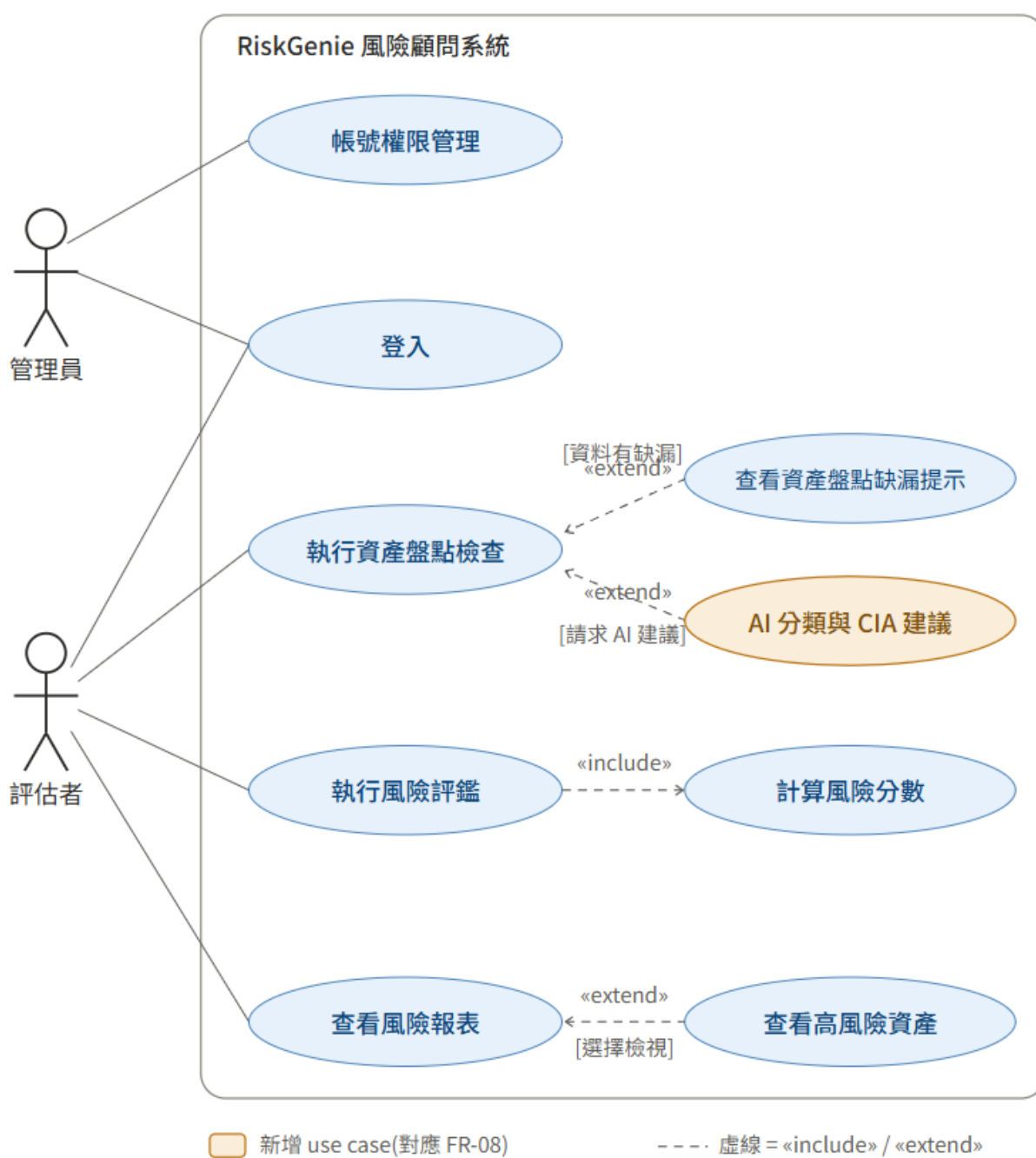


圖 5-2-1 使用個案圖

5-3 活動圖

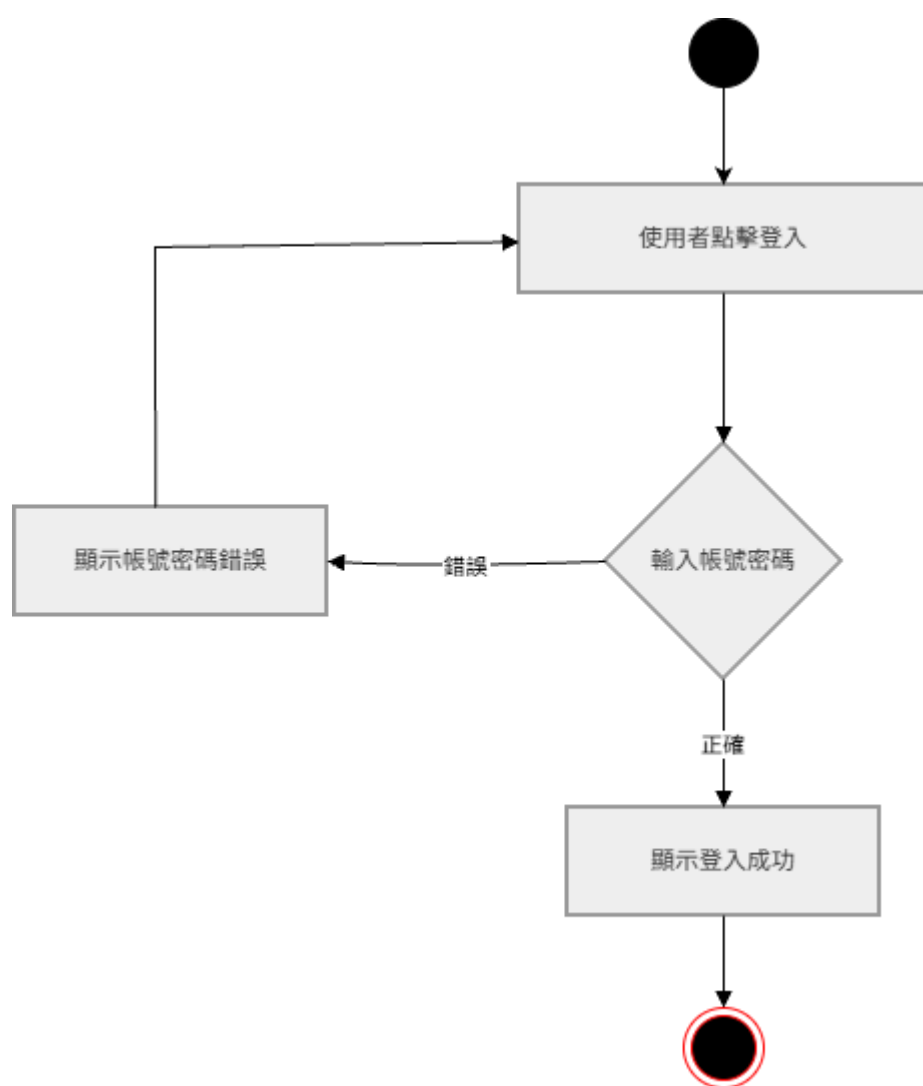


圖 5-3-1 活動圖－登入作業

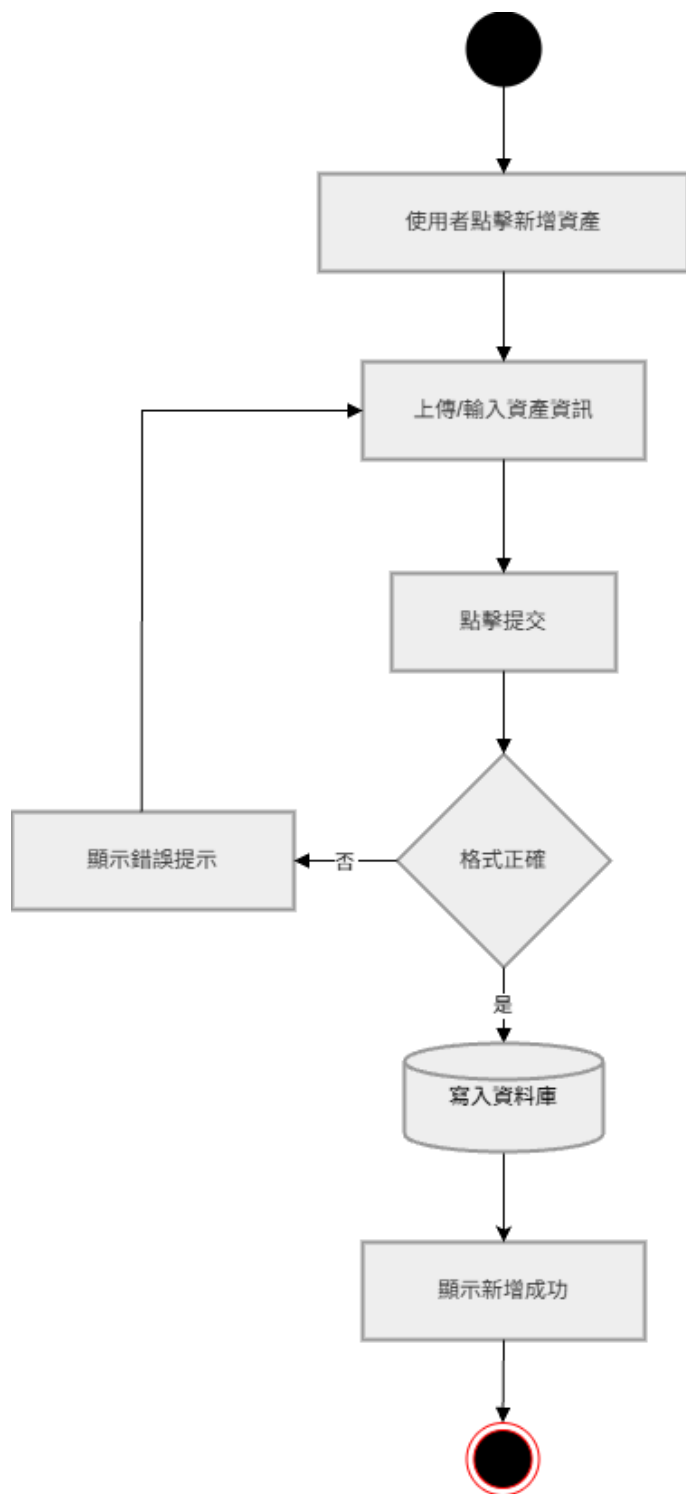


圖 5-3-2 活動圖—新增資訊資產作業

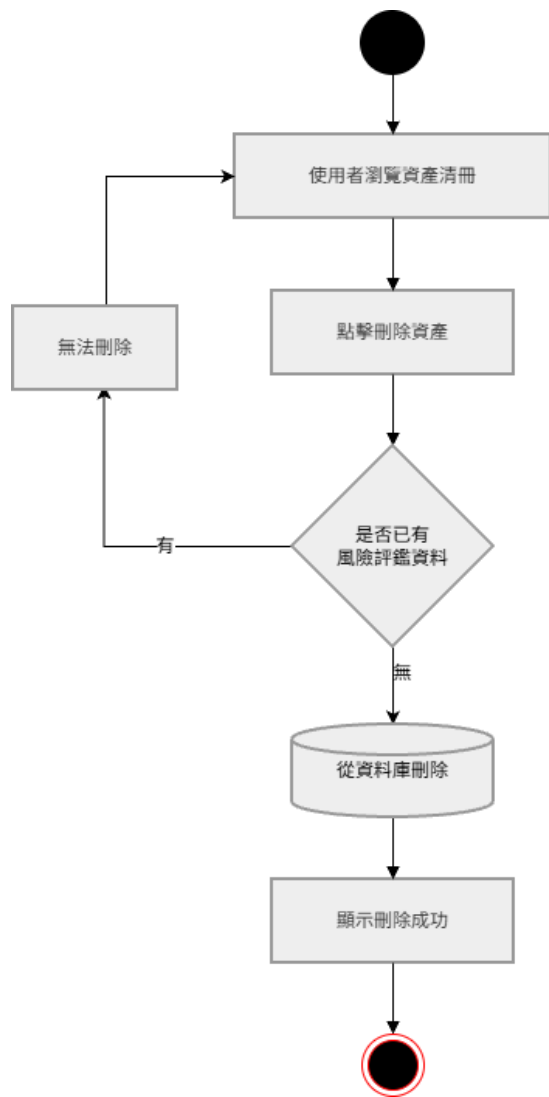


圖 5-3-3 活動圖－刪除資訊資產作業

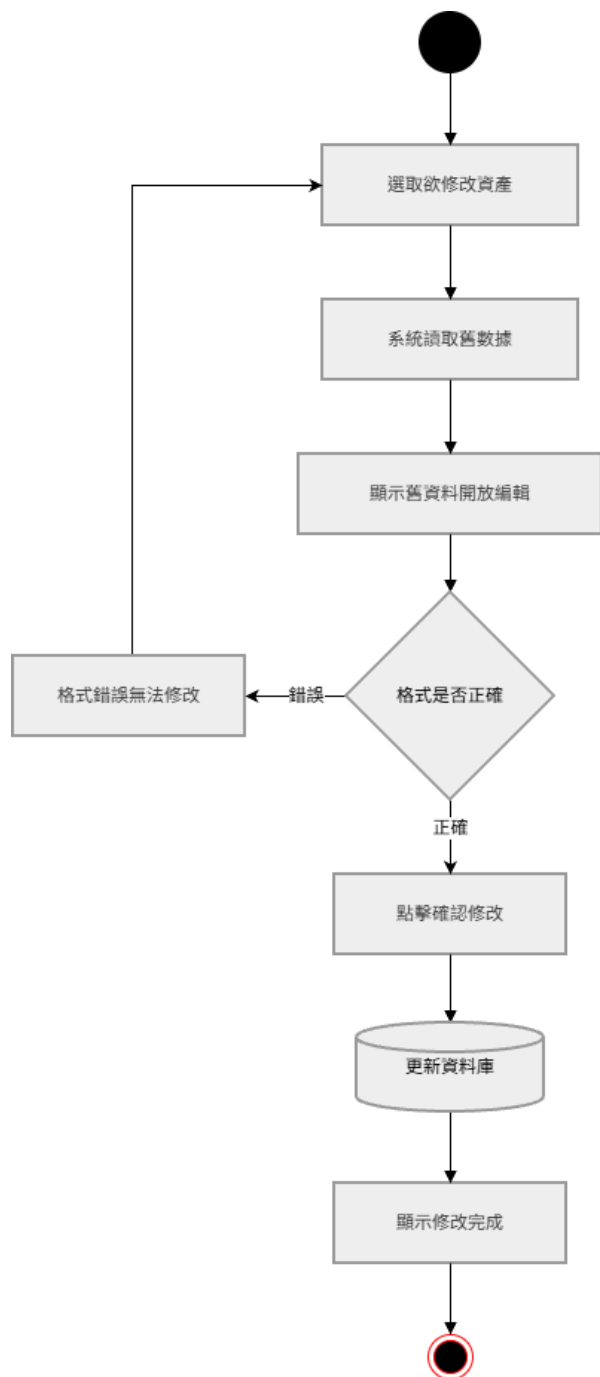


圖 5-3-4 活動圖－修改資訊資產作業

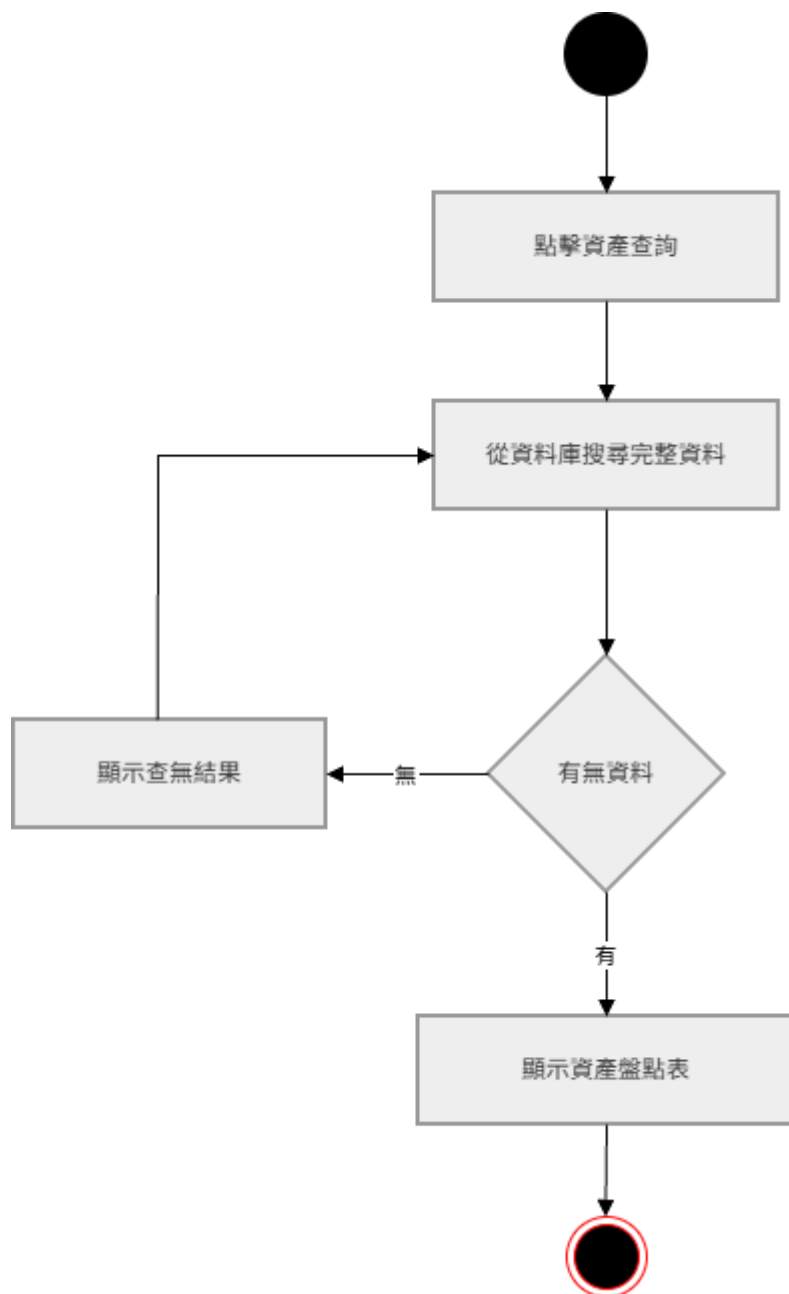


圖 5-3-5 活動圖－查詢資訊資產作業

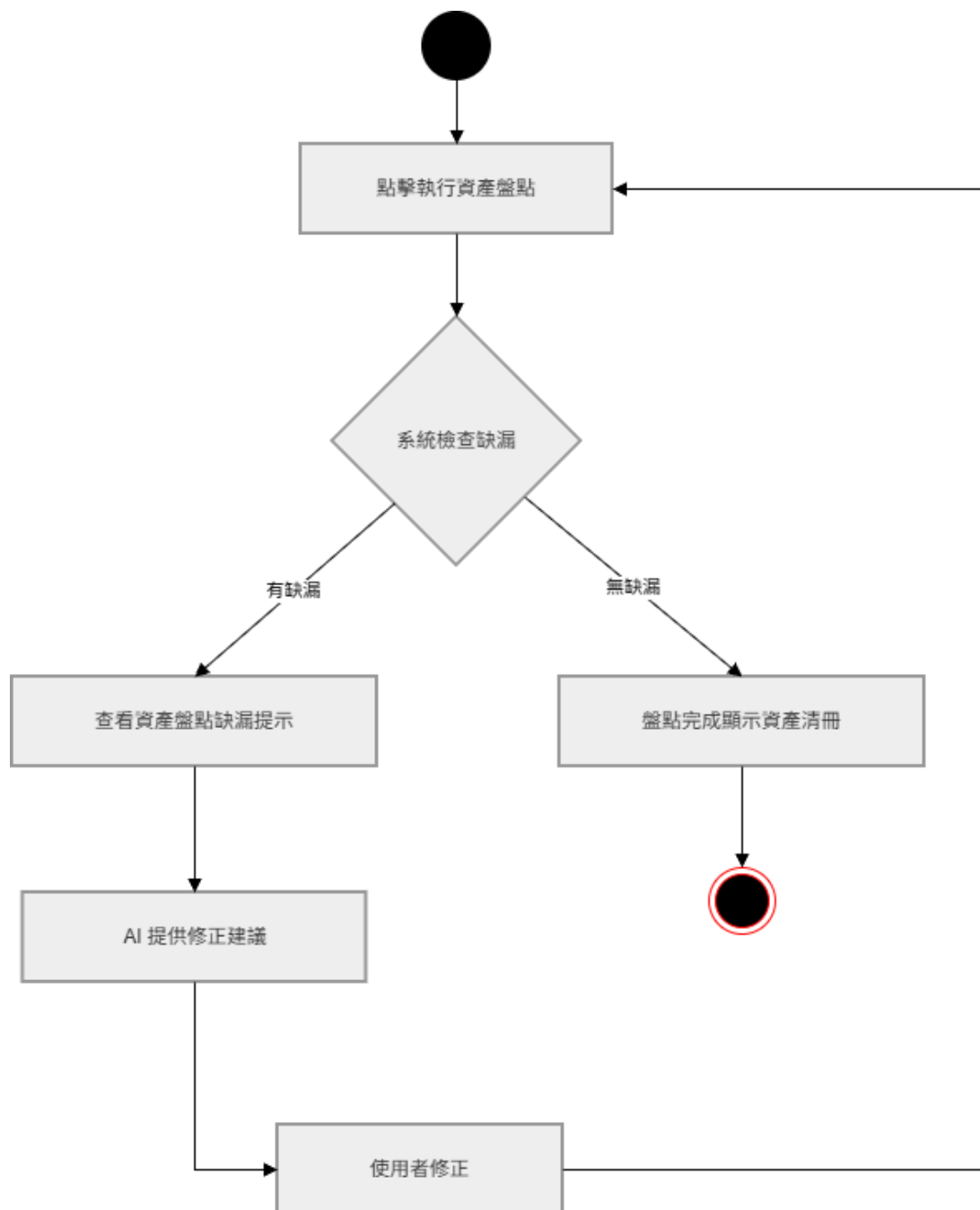


圖 5-3-6 活動圖－資產盤點與 AI 建議作業

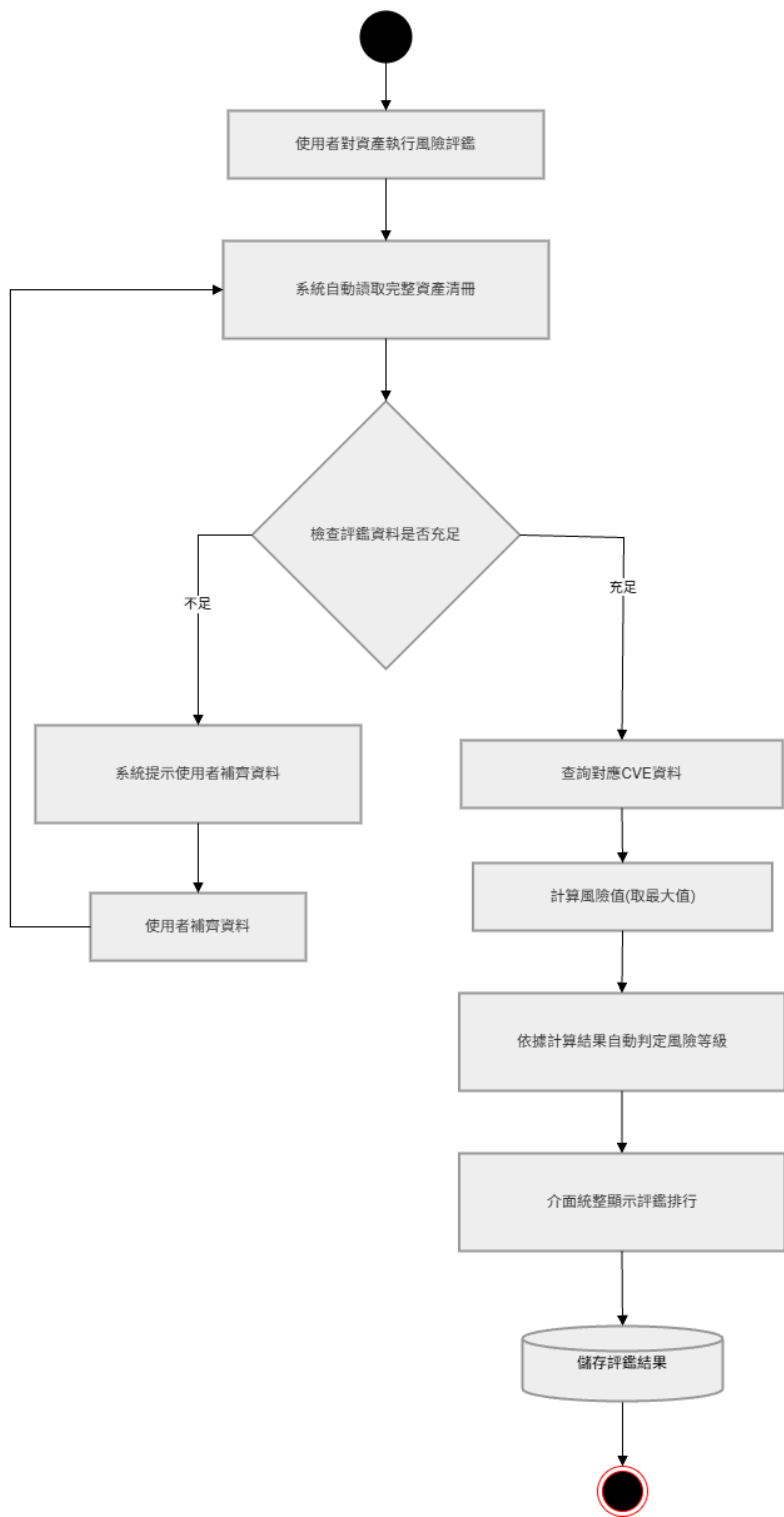


圖 5-3-7 活動圖－風險評鑑作業

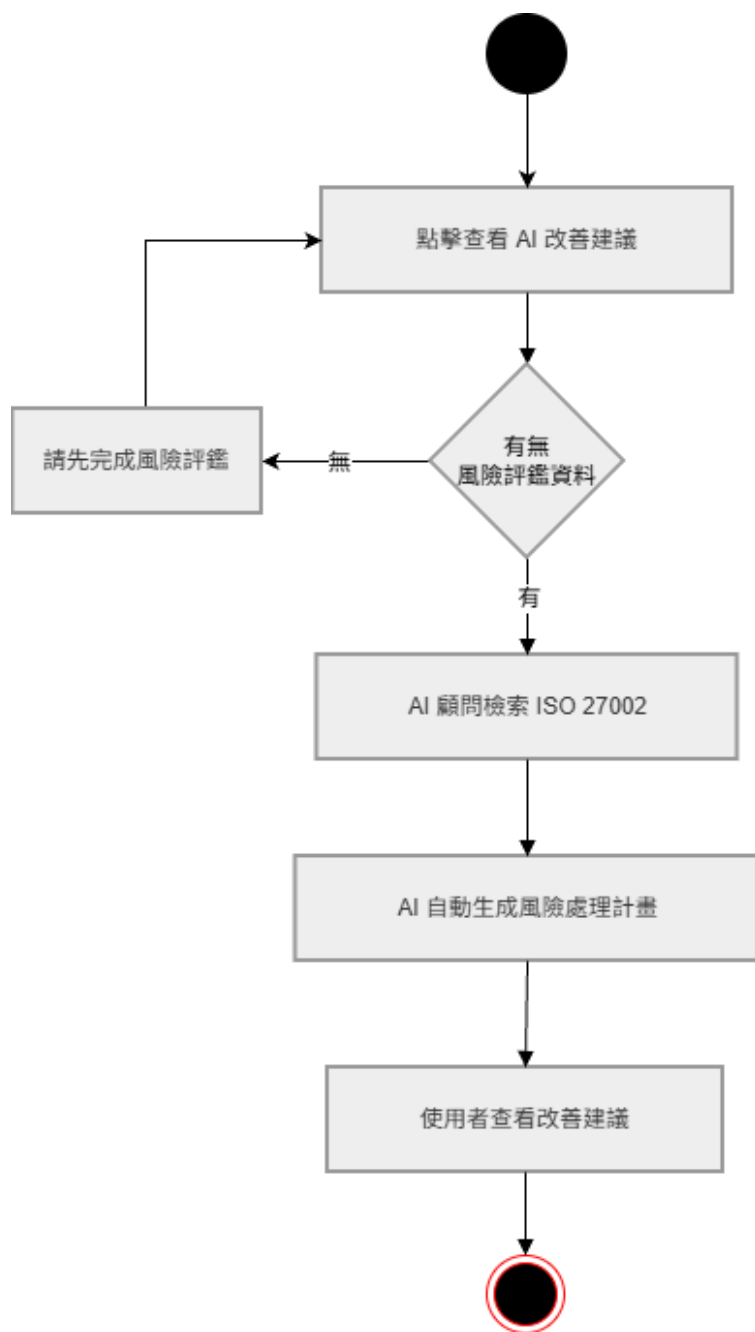


圖 5-3-8 活動圖－風險評鑑與 AI 建議作業

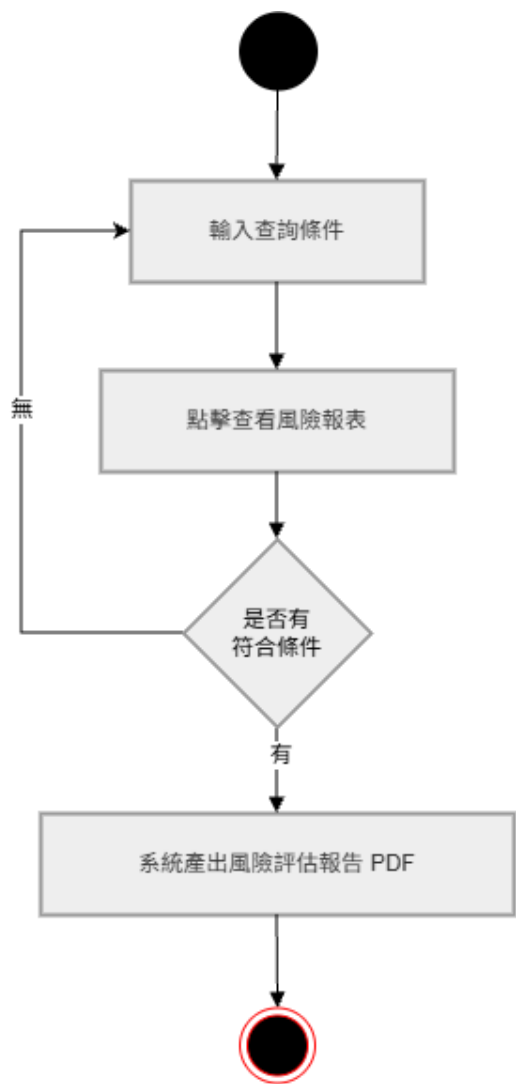


圖 5-3-9 活動圖－風險報表產生作業

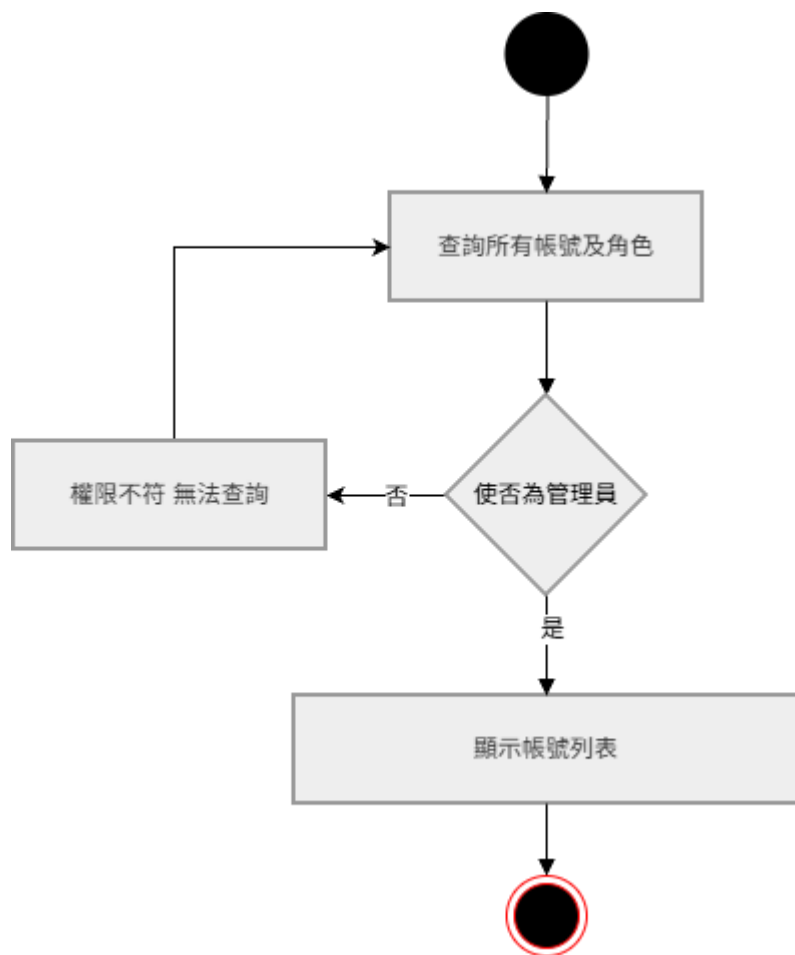


圖 5-3-10 活動圖－查詢帳號作業

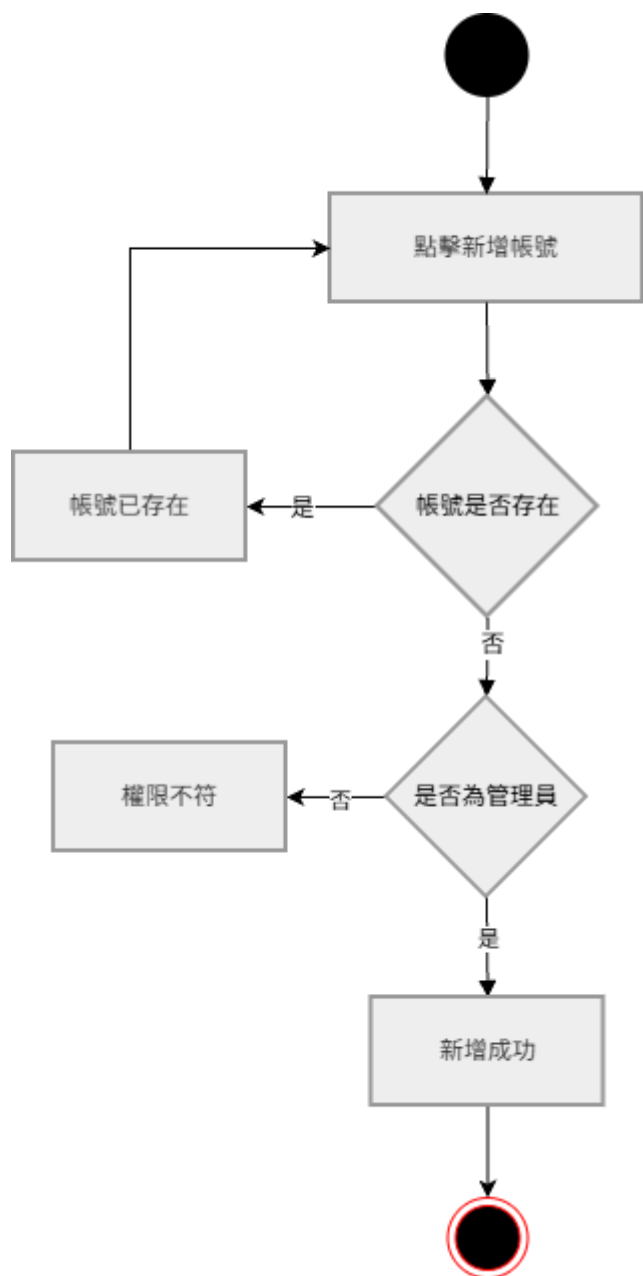


圖 5-3-11 活動圖—新增帳號作業

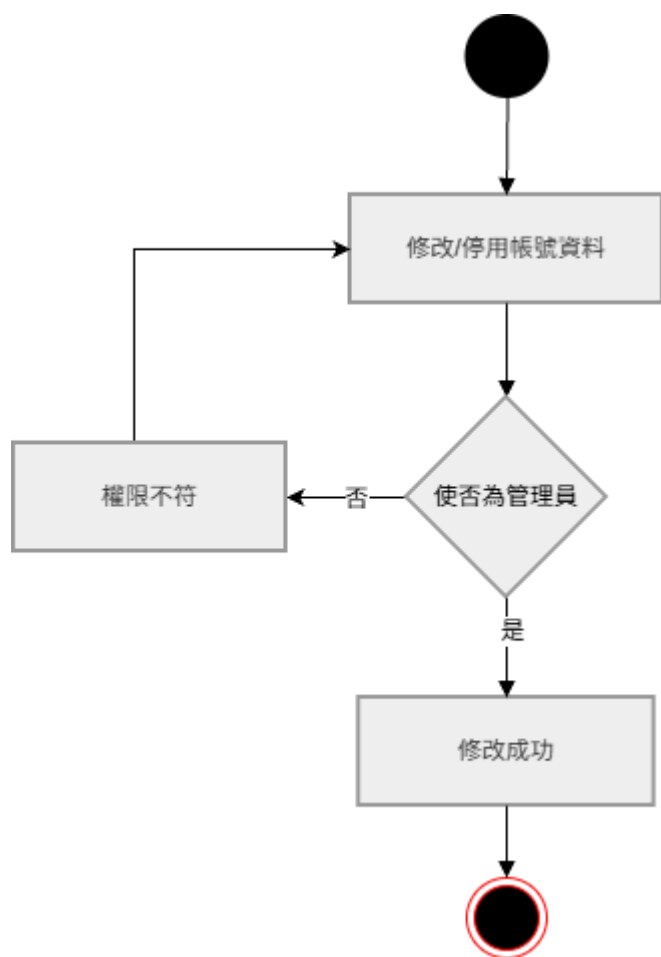


圖 5-3-12 活動圖－備份系統資料作業

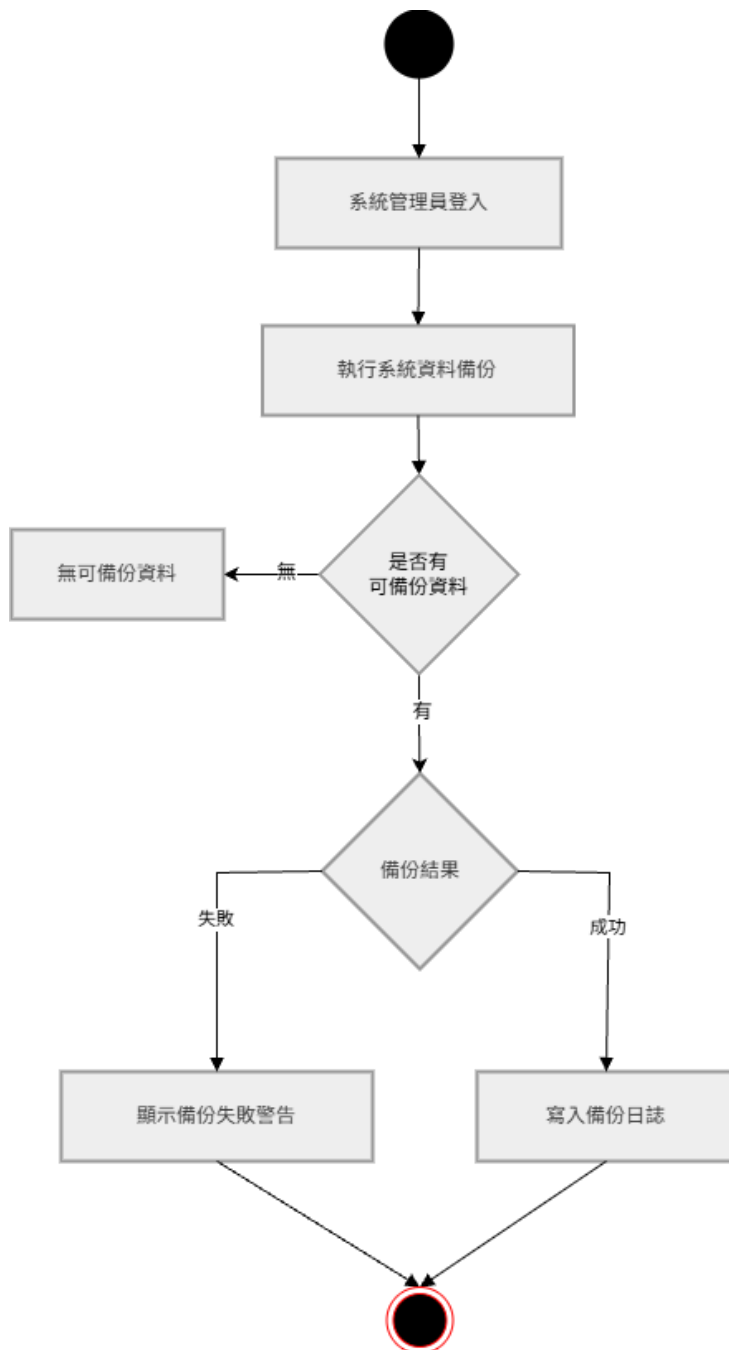


圖 5-3-13 活動圖－備份系統資料作業

5-4 分析類別圖

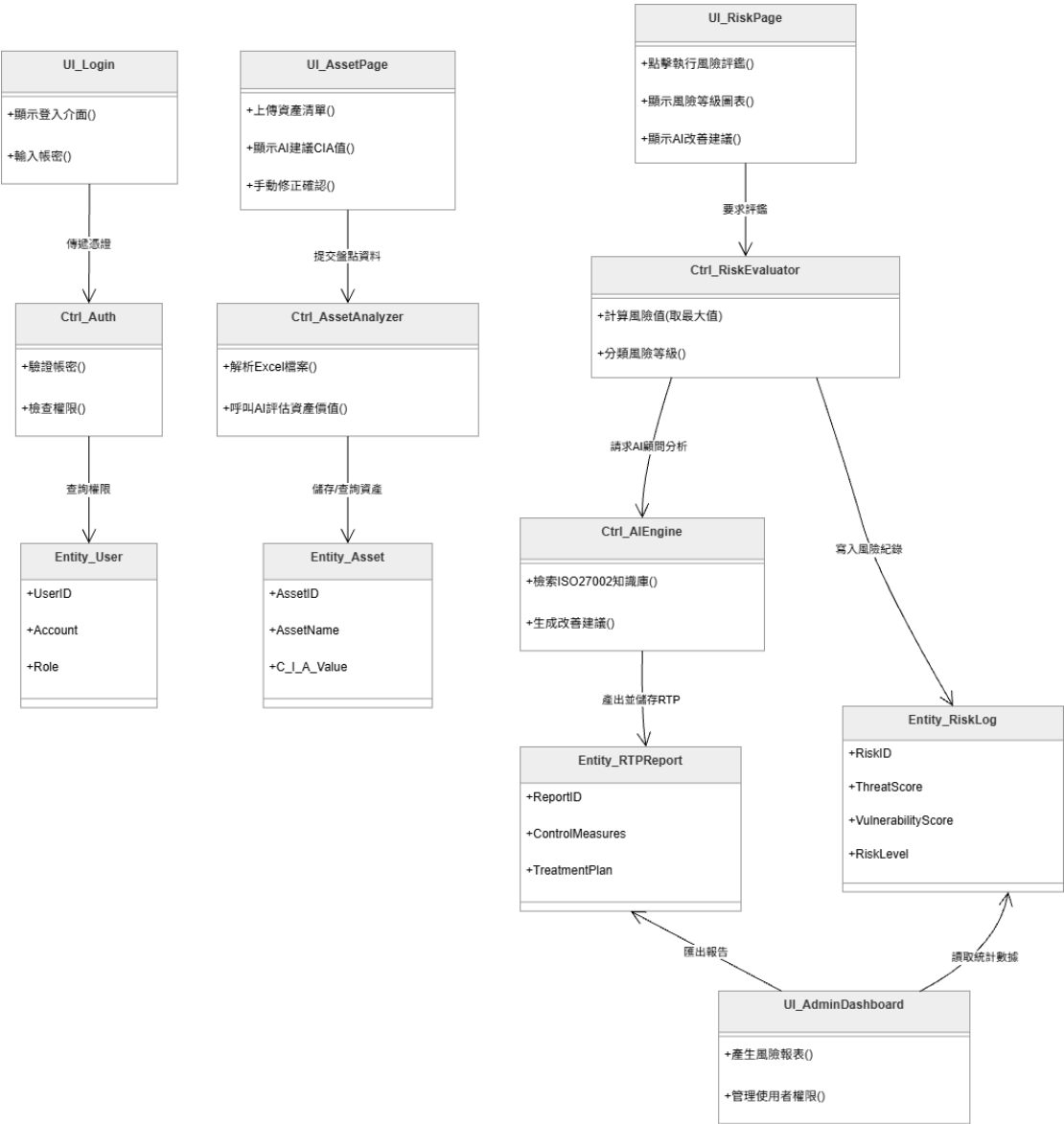


圖 5-4-1 分析類別圖

第 6 章 設計模型

6-1 循序圖

● 登入

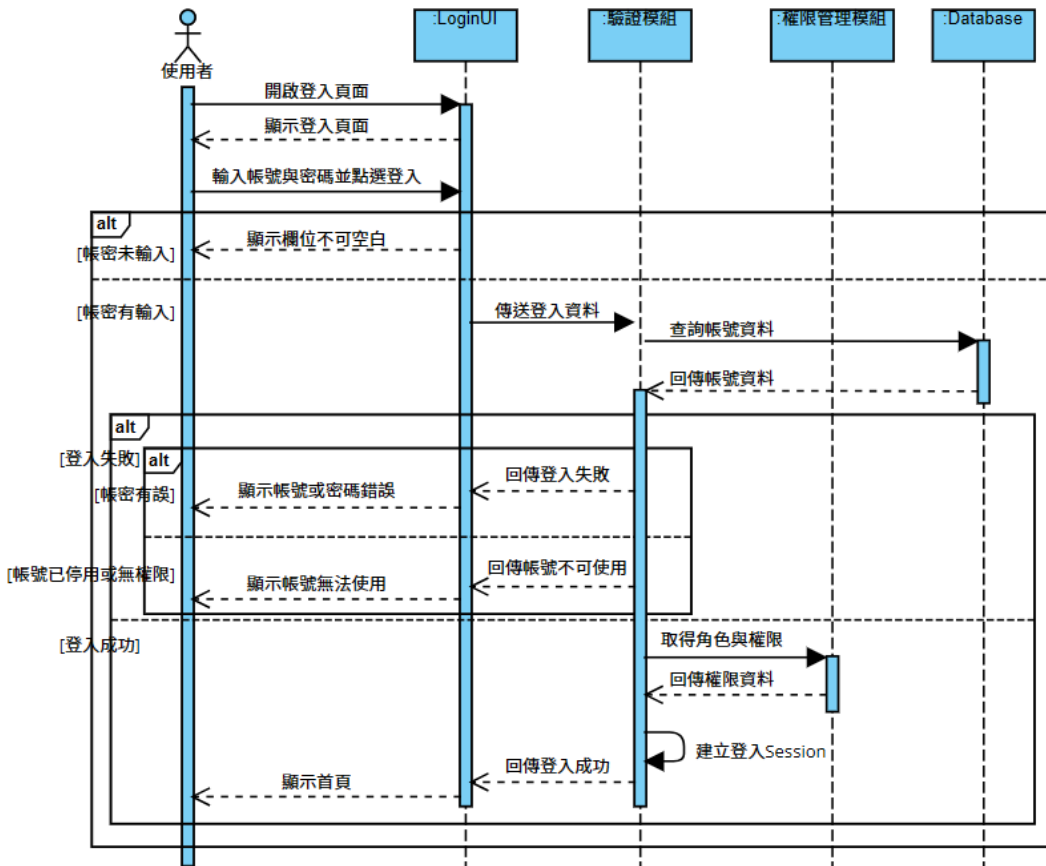


圖 6-1-1 循序圖－登入作業

● 資產盤點

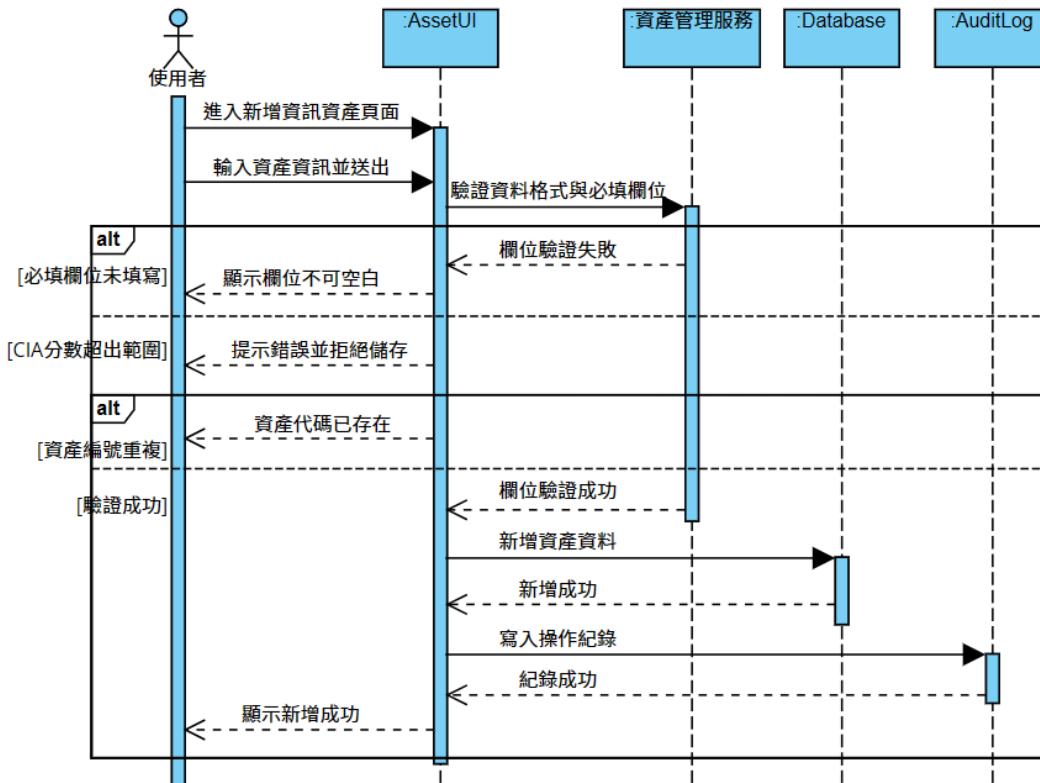


圖 6-1-2 循序圖—新增資訊資產作業

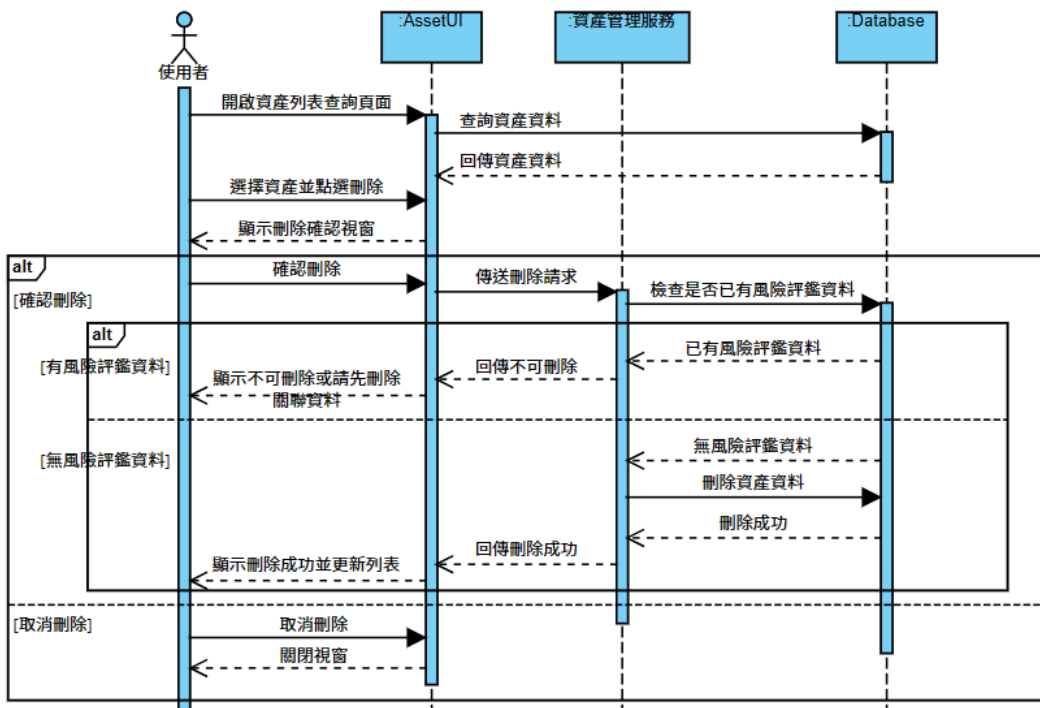


圖 6-1-3 循序圖—刪除資訊資產作業

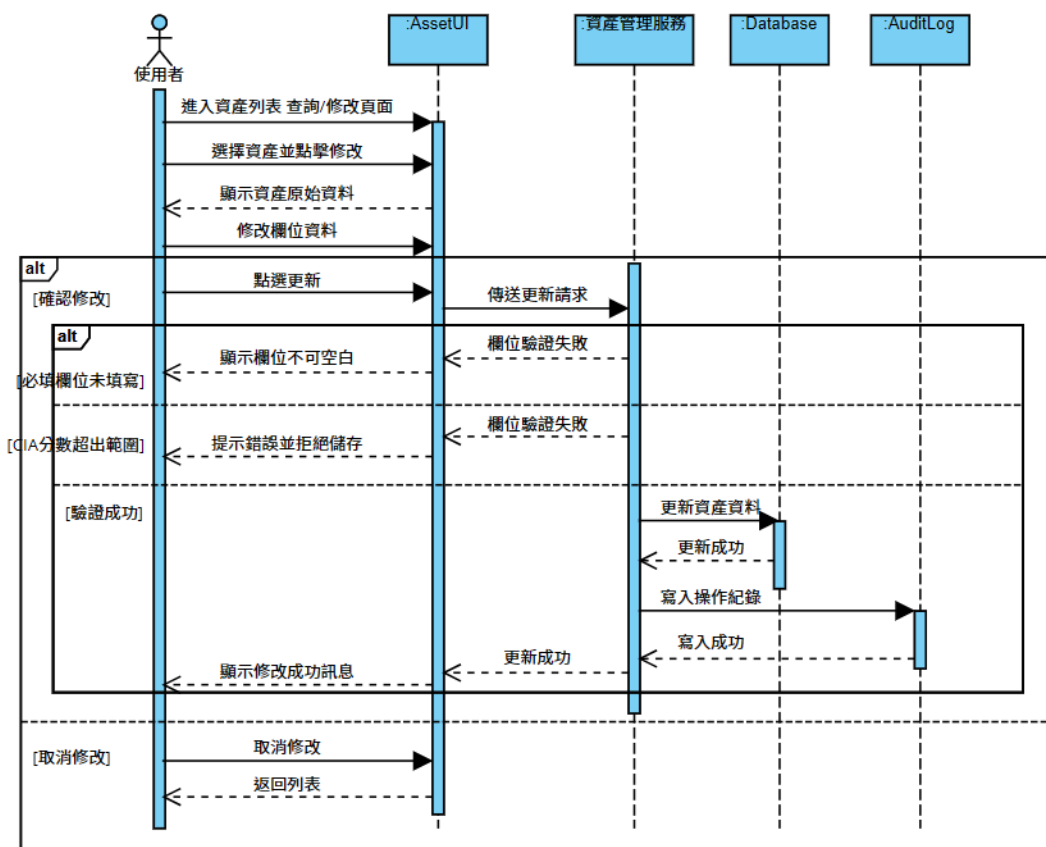


圖 6-1-4 循序圖－修改資訊資產作業

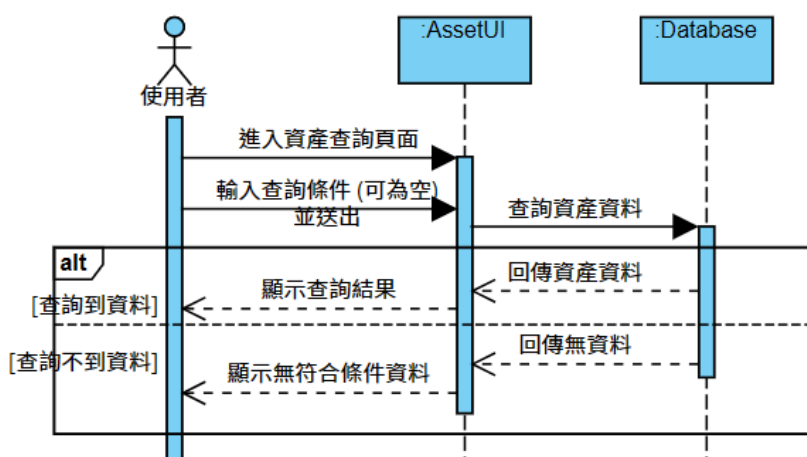


圖 6-1-5 循序圖－查詢資訊資產作業

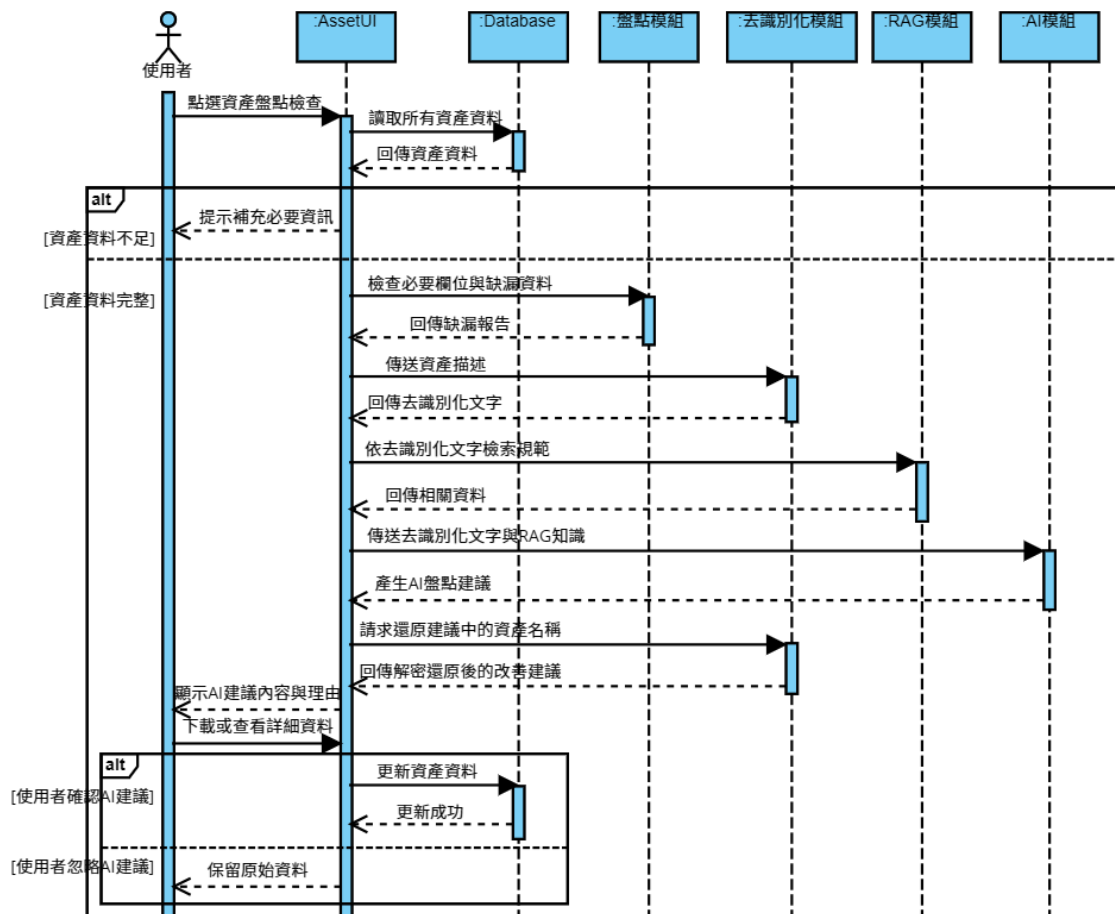


圖 6-1-6 循序圖－資產盤點與 AI 建議作業

● 風險評鑑

本系統以北商情境為案例，並採用 CIA 三項指標之最大值，結合 CVSS 分數，以計算系統之風險評分。

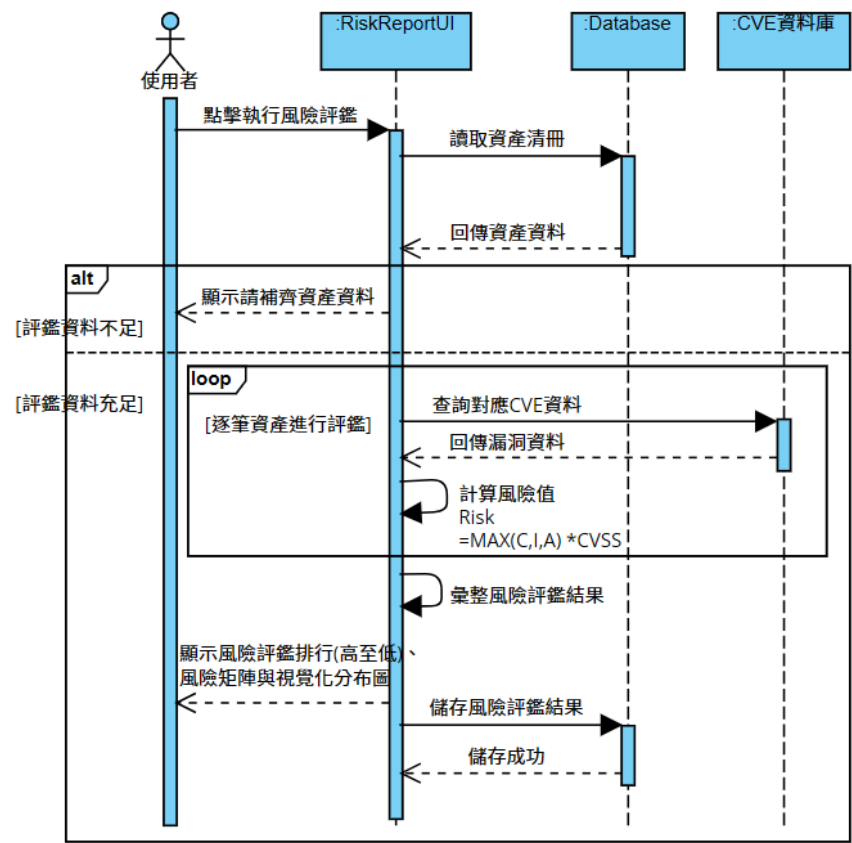


圖 6-1-7 循序圖－風險評鑑作業

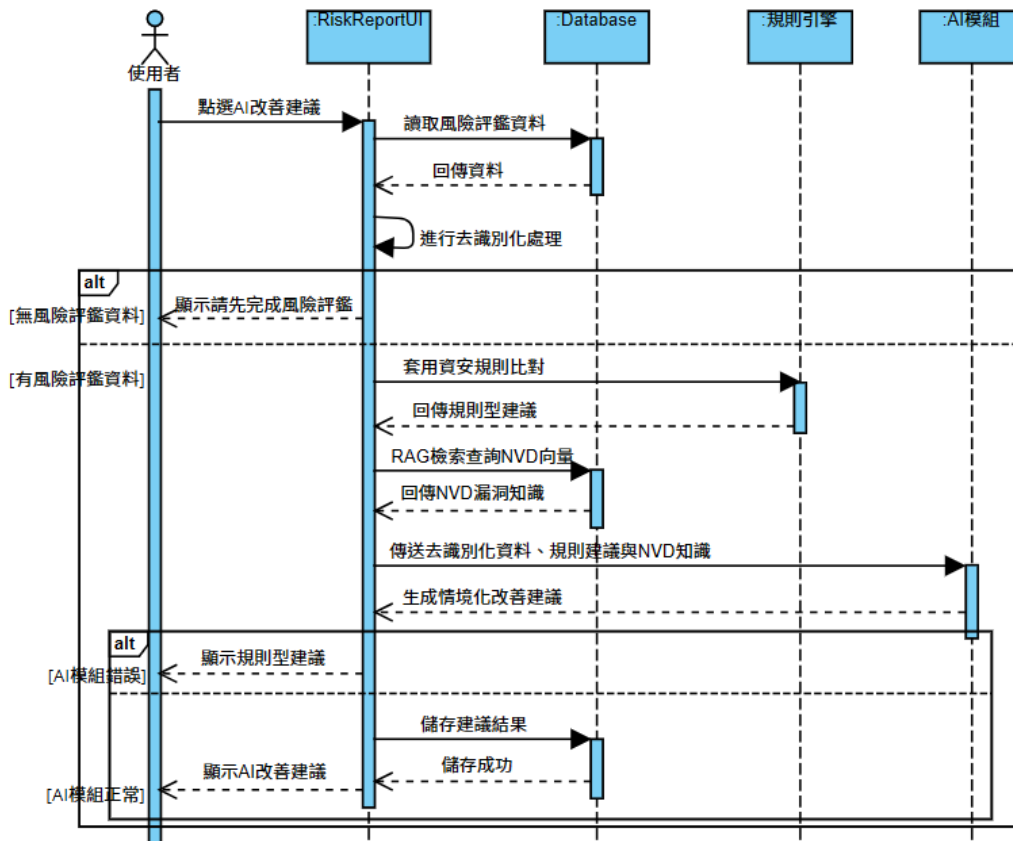


圖 6-1-8 循序圖－風險評鑑 AI 建議作業

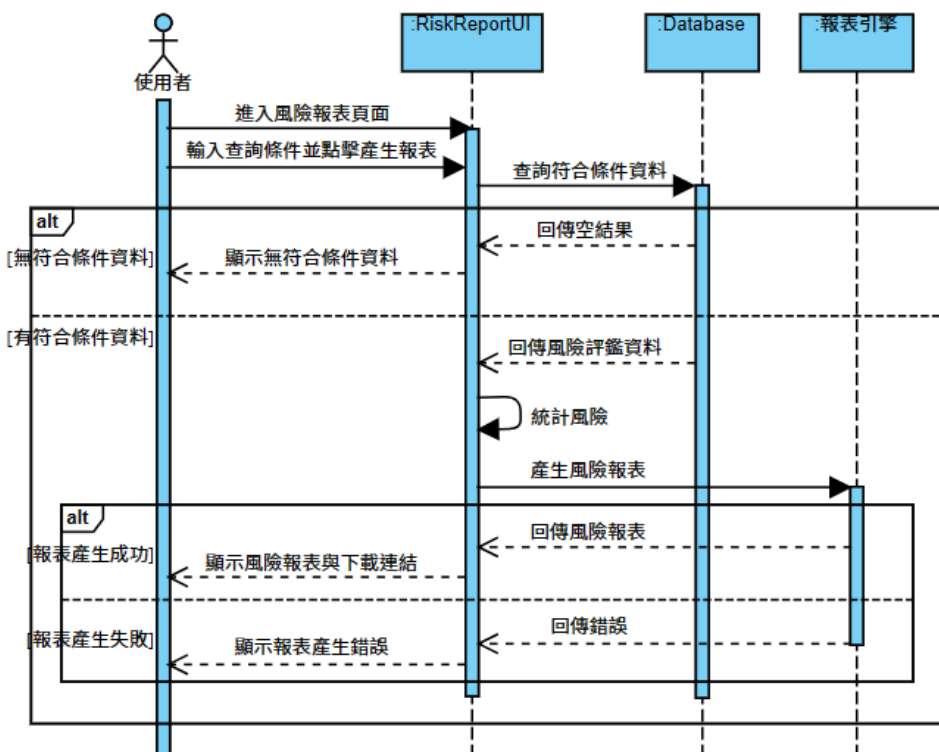


圖 6-1-9 循序圖－風險報表產生作業

● 帳號與權限管理

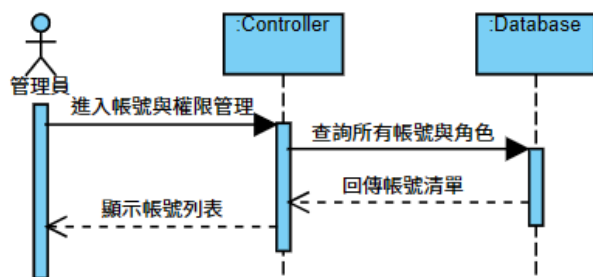


圖 6-1-10 循序圖－查詢帳號作業

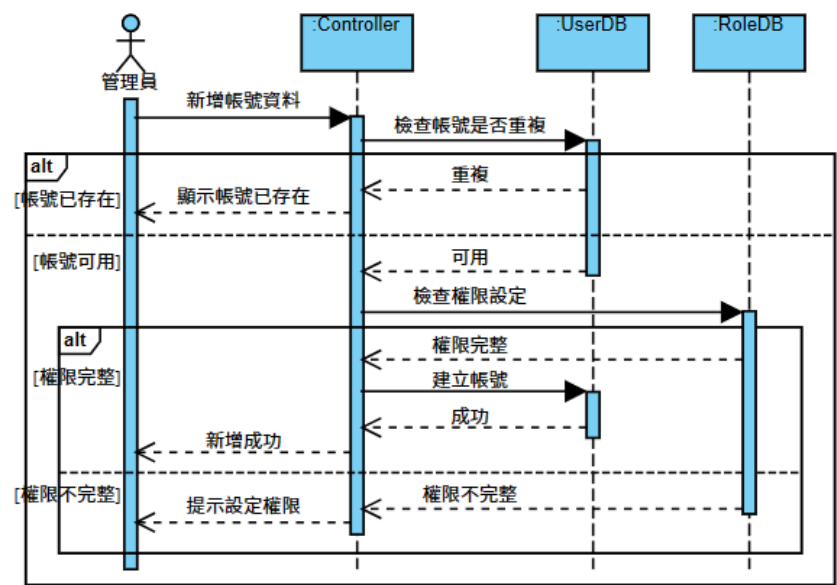


圖 6-1-11 循序圖－新增帳號作業

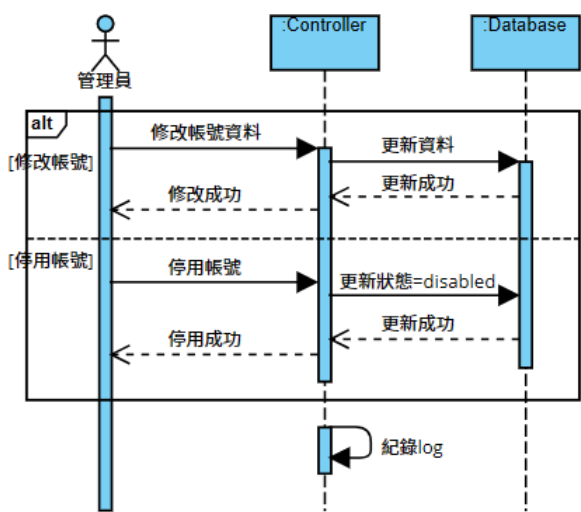


圖 6-1-12 循序圖－修改/停用帳號作業

● 備份

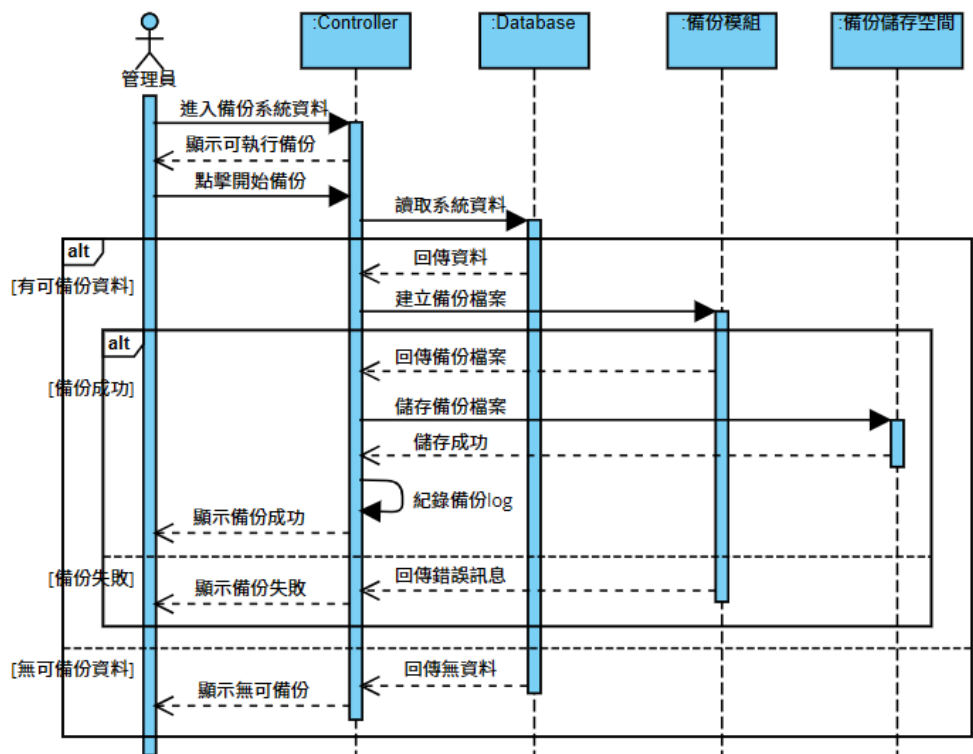


圖 6-1-13 循序圖－備份系統資料作業

6-2 設計類別圖

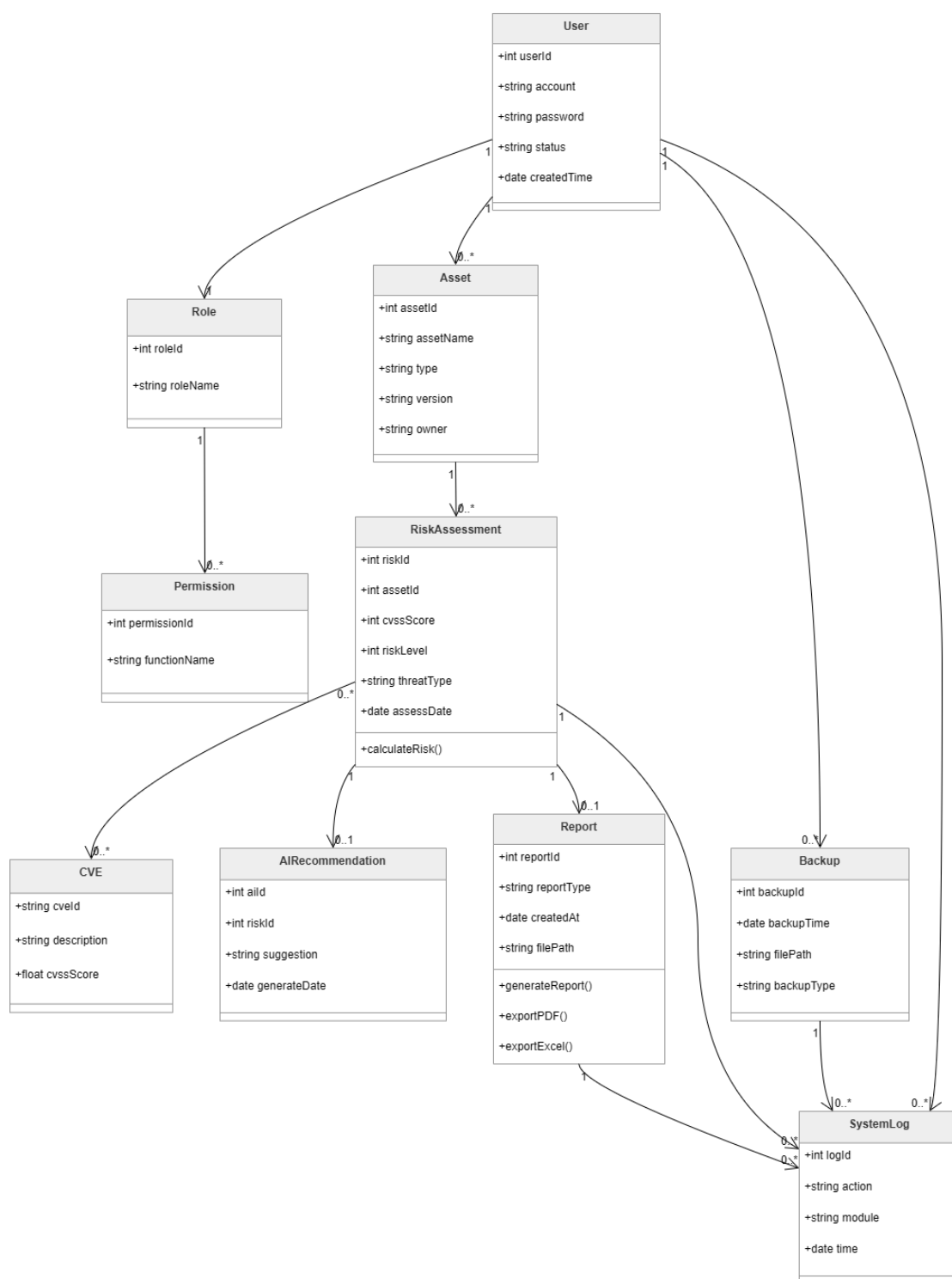


圖 6-2-1 設計類別圖

第 7 章 實作模型

7-1 佈署圖

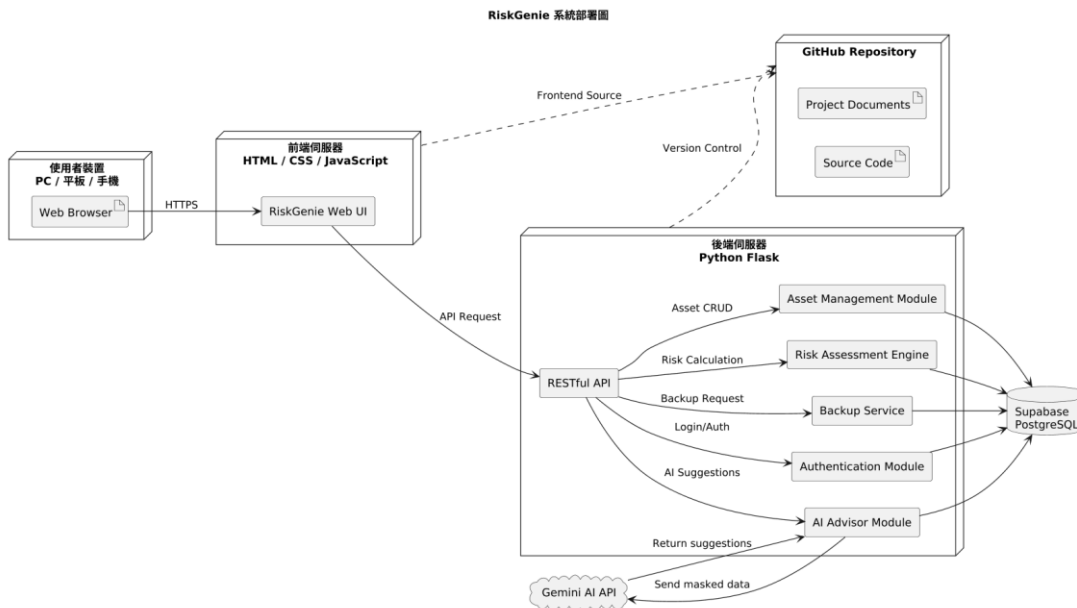


圖 7-1-1 佈署圖

7-2 套件圖

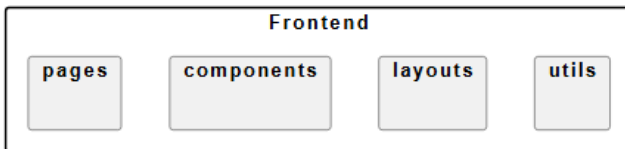


圖 7-2-1 前端套件圖

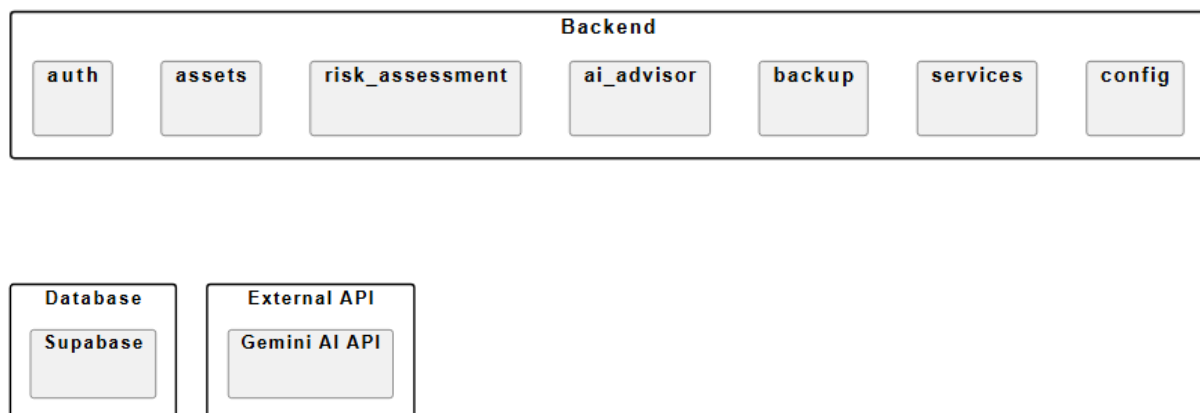


圖 7-2-2 後端套件圖

7-3 元件圖

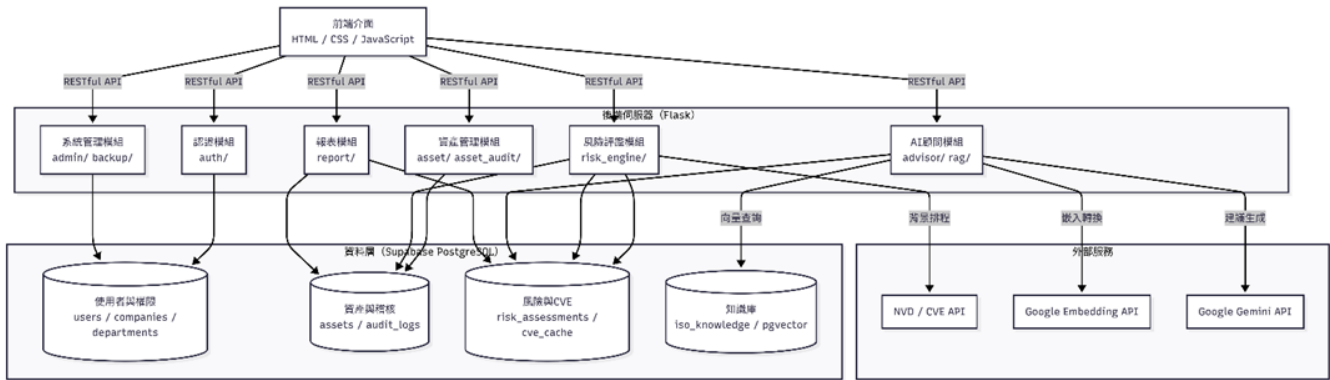


圖 7-3-1 元件圖

7-4 狀態機圖與時序圖

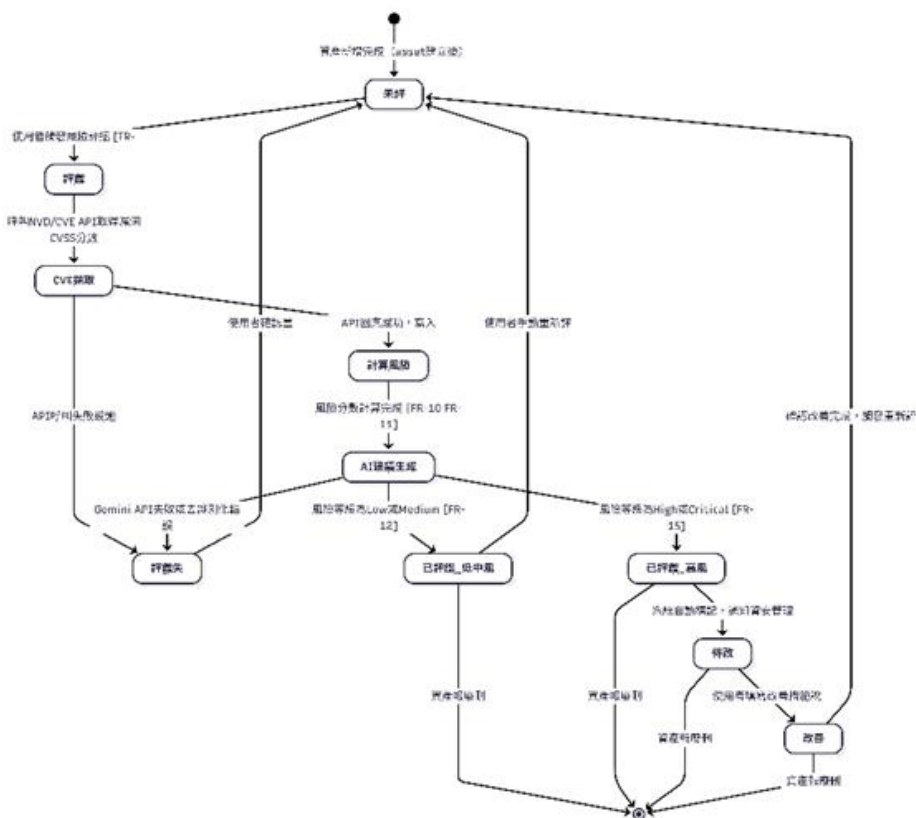


圖 7-4-1 狀態機圖

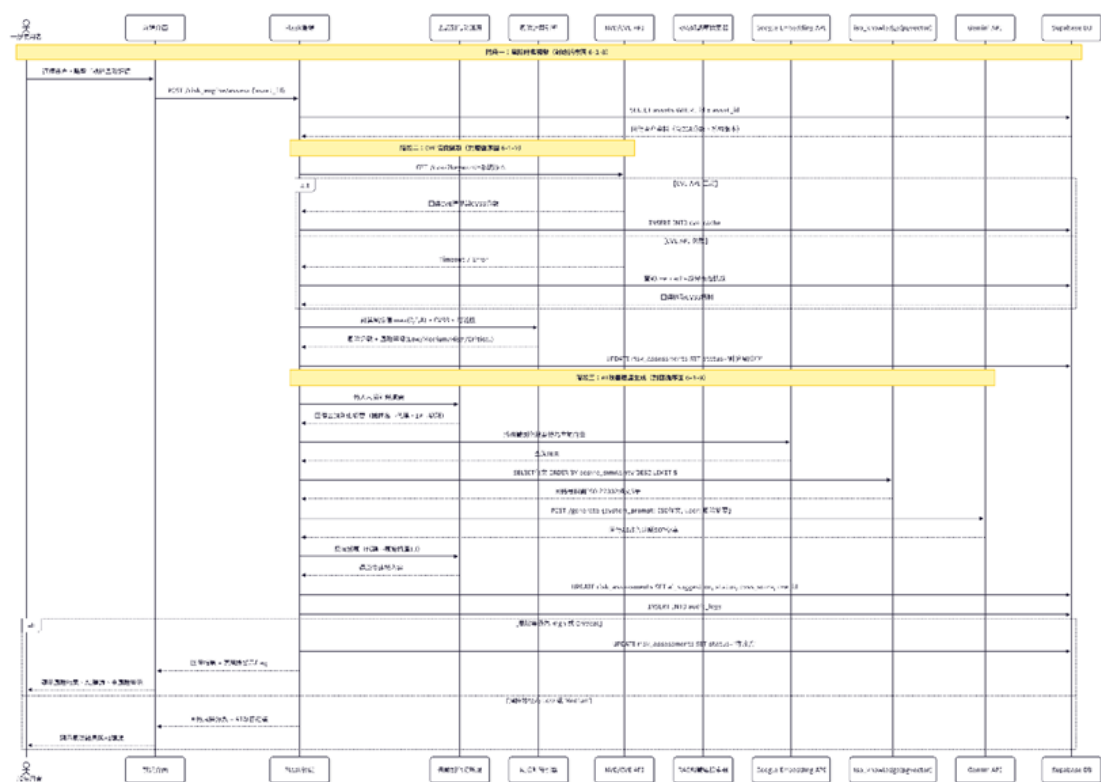


圖 7-4-2 時序圖

第 8 章 資料庫設計

8-1 資料庫關聯表（參考關係與限制 Constraints）

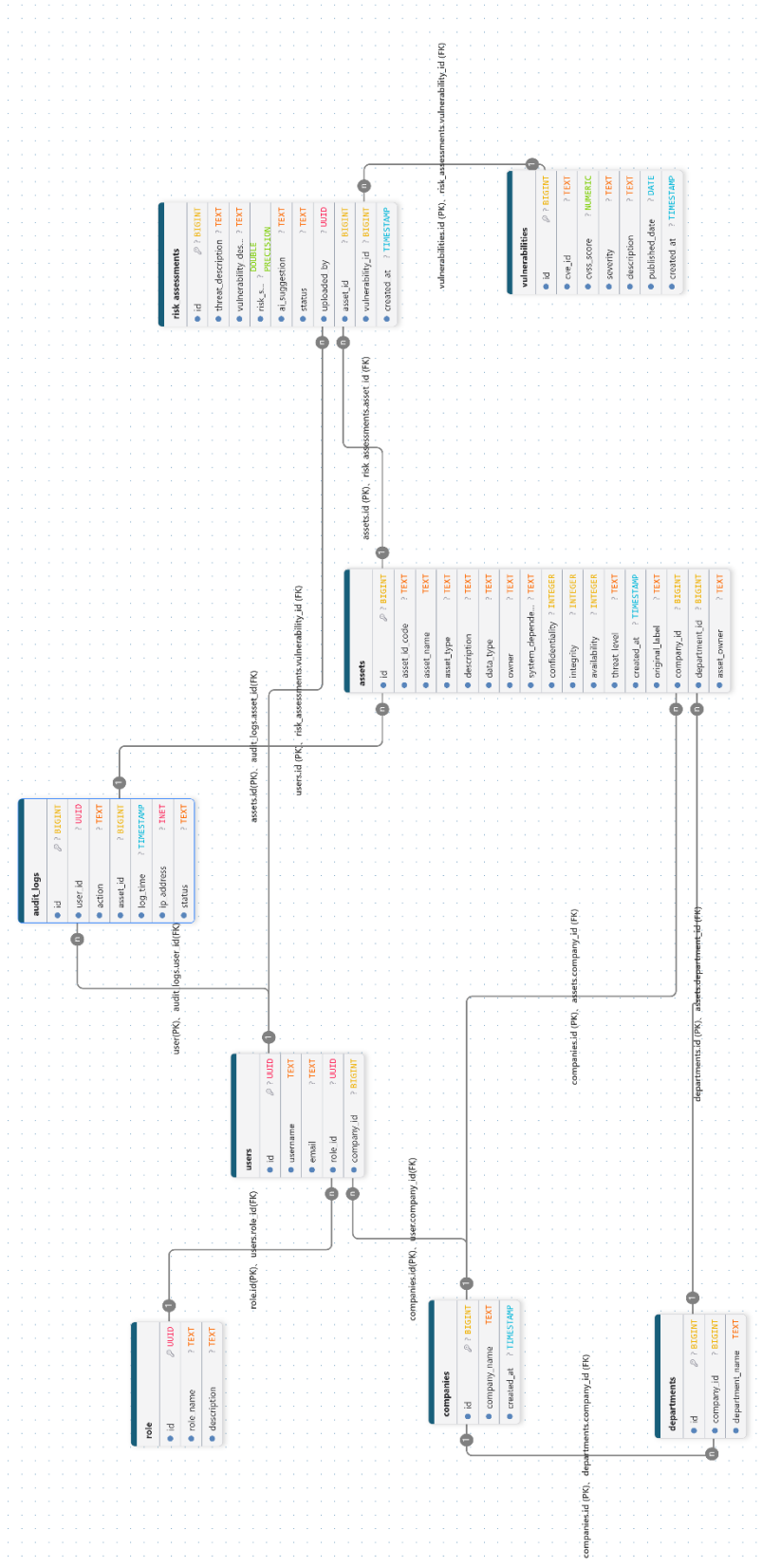


圖 8-1-1 資料庫關聯表

8-2 表格及其 Meta Data

表 8-2-1 companies(公司表) 欄位定義

欄位名稱	欄位型態	是否可空	描述	備註
id	int8	否	公司唯一識別碼	PK, Identity
company_name	text	否	公司名稱	
created_at	timestampz	是	建立時間	Default: now()

表 8-2-2 departments (部門表) 欄位定義

欄位名稱	欄位型態	是否可空	描述	備註
id	int8	否	部門唯一識別碼	PK, Identity
company_id	int8	否	所屬公司 ID	FK → companies.id
department_name	text	否	部門名稱	

表 8-2-3 role(角色表) 欄位定義

欄位名稱	欄位型態	是否可空	描述	備註
id	uuid	否	角色唯一識別碼	PK, Identity
role_name	text	否	系統角色名稱 (如一般使用者 資安管理員／高階主管 系統管理員)	Unique
description	text	否	角色權限或職責說明	

表 8-2-4 users (使用者表) 欄位定義

欄位名稱	欄位型態	是否可空	描述	備註
id	uuid	否	使用者唯一識別碼	PK
username	text	否	使用者名稱	Unique
email	text	否	電子郵件	Unique
role_id	uuid	否	使用者角色識別碼	FK → role.id
company_id	int8	否	所屬公司識別碼	FK → companies.id

表 8-2-5 assets (資產表) 欄位定義

欄位名稱	欄位型態	是否可空	描述	備註
id	int8	否	資產唯一識別碼	PK, Identity
asset_id_code	text	是	資產代碼	Unique

asset_name	text	否	資產名稱	
asset_type	text	是	資產類型	
description	text	是	資產描述	
data_type	text	是	資料類型	
owner	text	是	原始負責人	
system_dependency	text	是	系統相依性	
confidentiality	int4	是	機密性等級	
integrity	int4	是	完整性等級	
availability	int4	是	可用性等級	
threat_level	text	是	威脅等級	
created_at	timestampz	是	建立時間	Default: now()
original_label	text	是	原始標籤	
company_id	int8	是	所屬公司 ID	FK → companies.id
department_id	int8	是	所屬部門 ID	FK → departments.id
asset_owner	text	是	資產擁有者	

表 8-2-6 vulnerabilities (弱點表) 欄位定義

欄位名稱	欄位型態	是否可空	描述	備註
id	int8	否	弱點唯一識別碼	PK, Identity
cve_id	text	是	CVE 編號	Unique
cvss_score	numeric	是	CVSS 分數	
severity	text	是	嚴重程度	
description	text	是	弱點描述	
published_date	date	是	發布日期	
created_at	timestampz	是	建立時間	Default: now()

表 8-2-7 risk_assessments (AI 風險分析結果表) 欄位定義

欄位名稱	欄位型態	是否可空	描述	備註
id	int8	否	風險評估唯一識別碼	PK, Identity
threat_description	text	是	威脅描述	
vulnerability_description	text	是	弱點描述	
risk_score	float8	是	風險分數	
ai_suggestion	text	是	AI 建議	
status	text	是	狀態	
uploaded_by	uuid	否	上傳者	FK → users.id
asset_id	int8	否	資產 ID	FK → assets.id

vulnerability_id	int8	是	弱點 ID	FK → vulnerabilities.id
created_at	timestampz	是	建立時間	Default: now()

表 8-2-8 audit_logs (稽核紀錄表) 欄位定義

欄位名稱	欄位型態	是否可空	描述	備註
id	int8	否	日誌唯一識別碼	PK, Identity
user_id	uuid	否	操作者	FK → users.id
action	text	否	動作類型	執行動作 (新增／修改／刪除)
asset_id	int8	是	目標資產	FK → assets.id
log_time	timestampz	是	操作時間	Default: now()
ip_address	inet	否	操作者 IP 位址	記錄來源網路位址
status	text	否	操作結果狀態	成功／失敗

組織與權限管理

- companies.id → departments.company_id (1:N)
- companies.id → users.company_id (1:N)
- roles.id → users.role_id (1:N)

資產管理

- companies.id → assets.company_id (1:N)
- departments.id → assets.department_id (1:N)

風險評估管理

- users.id → risk_assessments.uploaded_by (1:N)
- assets.id → risk_assessments.asset_id (1:N)
- vulnerabilities.id → risk_assessments.vulnerability_id (1:N)

稽核管理

- users.id → audit_logs.user_id (1:N)

- assets.id → audit_logs.asset_id (1:N)

本本專題旨在建置一套基於資產導向之資安風險管理系統，透過 Supabase 建立關聯式資料庫架構，整合資產管理、弱點資訊與風險評估流程，以提升組織對資訊資產之可視性與風險掌握能力。系統以 assets 作為核心資料表，串聯 vulnerabilities 與 risk_assessments，形成從資產識別、弱點關聯到風險評估結果記錄之完整資料流程，使風險分析結果能夠有效被保存與追蹤。

此外，系統透過 users 表實現使用者身分識別與基本權限控管機制，確保資料存取之安全性與一致性；audit_logs 則負責記錄所有關鍵操作行為，提供完整的稽核追蹤能力，以支援後續的安全審查與管理需求。整體資料庫設計遵循關聯式資料庫正規化原則，所有外鍵皆指向主鍵 (id)，以確保資料一致性與系統穩定性。

綜合而言，本系統不僅實現資產與風險之整合管理，也符合資訊安全管理系統 (ISMS) 對於可追溯性、完整性與管理流程控制之基本要求，具備實務應用於中小型組織資訊安全管理之潛力。

第 14 章 參考資料

※使用人工智慧或生成式人工智慧做為輔助作品產出工具之說明：

☐未使用人工智慧科技做為輔助作品產出之工具（以下免填）

☒使用人工智慧科技做為輔助作品產出之工具（請填下表，表格不足請自行增列）

序號	使用工具名稱	使用範圍及說明	頁碼
1	Gemini	背景介紹及預期成果使用 Gemini 內容修飾	1
2	ChatGPT	成本結構及收益流內容建議	8-9
3	ChatGPT	開發工具與技術說明使用 ChatGPT 內容修飾	15-16
4	Claude	需求說明內容修飾	22-23
5	ChatGPT	第 8 章結尾內容修飾	55

其他參考資料：

E 等公務園

(1) ISMS 認證流程導覽

(2) ISO 27001 控制措施與資通系統防護基驗證實務

(3) 資通系統盤點及安全等級評估

IS Capt. AI 智慧資安管理平台-系統手冊.pdf

動起來「揪」對了-系統手冊.pdf

檢索增強生成與微調大語言模型於資安管理應用之研究.pdf